

Bộ Giáo Dục Và Đào Tạo
Trường Đại Học Ngoại Ngữ - Tin Học Thành Phố Hồ Chí Minh
Khoa Công Nghệ Thông Tin



ĐỒ ÁN MÔN HỌC: QUẢN TRỊ HỆ THỐNG BẢO MẬT
ĐỀ TÀI: XÂY DỰNG CHÍNH SÁCH BẢO MẬT CHO DOANH
NGHIỆP KINH DOANH ĐIỆN THOẠI DI ĐỘNG VÀ TRIỂN
KHAI DEMO

Giảng viên hướng dẫn : ThS. Đinh Xuân Lâm

Sinh viên thực hiện : Phan Trần Anh Đức - 23DH110838
Vũ Thị Thanh Huế - 23DH111162
Bùi Viết Nguyên Chương-23DH110383

TP. HỒ CHÍ MINH, Tháng 4 Năm 2026

[illegible]

PHIẾU CHẤM ĐIỂM MÔN THI VẤN ĐÁP

Điểm phần trình bày – Điểm hệ số 10:

	CBCT1	CBCT2
Họ và tên CBCT	 Chữ ký:.....	 Chữ ký:.....
Điểm thi	 Bằng chữ: 	 Bằng chữ:
Nhận xét: Báo cáo: 2đ Vấn đáp: 2đ Chức năng và demo: 5đ Mở rộng và ứng dụng thực tiễn: 1đ	Quyền báo cáo: (...)điểm... Vấn đáp: (...) điểm... Chức năng: (...) điểm... Mở rộng: (...) điểm... 	Quyền báo cáo: (...)điểm... Vấn đáp: (...) điểm... Chức năng: (...) điểm... Mở rộng: (...) điểm...

Điểm quá trình – Điểm hệ số 10:

Họ và tên của CBCT:

.....

Điểm tổng kết:(Bảng chữ.....)

LỜI MỞ ĐẦU

Trong bối cảnh kỷ nguyên số bùng nổ, thông tin đã trở thành tài sản quý giá nhất của mọi doanh nghiệp. Đối với các đơn vị kinh doanh điện thoại di động – nơi lưu trữ khối lượng lớn dữ liệu khách hàng, giao dịch tài chính và thông tin bảo hành – việc đảm bảo tính bảo mật là yếu tố sống còn. Tuy nhiên, đi kèm với sự phát triển công nghệ là các mối đe dọa an ninh mạng ngày càng tinh vi, từ các cuộc tấn công mã độc đến việc rò rỉ dữ liệu nội bộ.

Thực tế cho thấy, nhiều doanh nghiệp bán lẻ hiện nay vẫn còn lúng túng trong việc thiết lập một quy trình bảo mật chuẩn chỉnh. Điều này không chỉ gây rủi ro về mặt tài chính mà còn làm tổn hại nghiêm trọng đến uy tín thương hiệu. Nhận thức được tầm quan trọng đó, trong phạm vi môn học Quản trị hệ thống bảo mật, em đã lựa chọn đề tài: “Xây dựng chính sách bảo mật cho doanh nghiệp kinh doanh điện thoại di động và triển khai Demo”.

Đề án này tập trung vào việc phân tích các lỗ hổng bảo mật đặc thù trong mô hình kinh doanh bán lẻ, từ đó đề xuất các chính sách quản trị hệ thống chặt chẽ. Đồng thời, phần triển khai Demo sẽ mô phỏng các giải pháp kỹ thuật cụ thể nhằm minh chứng cho tính khả thi và hiệu quả của chính sách đã xây dựng, giúp doanh nghiệp chủ động hơn trong việc bảo vệ hạ tầng thông tin trước các nguy cơ tiềm ẩn.

LỜI CẢM ƠN

Để hoàn thành đồ án này một cách tốt đẹp, em đã nhận được sự hỗ trợ, hướng dẫn và động viên rất lớn từ phía Nhà trường, thầy cô và gia đình.

Trước hết, em xin gửi lời cảm ơn chân thành sâu sắc nhất đến thầy Đinh Xuân Lâm – Giảng viên bộ môn Quản trị hệ thống bảo mật. Trong suốt quá trình học tập và thực hiện đề tài, thầy đã tận tình hướng dẫn, truyền đạt những kiến thức chuyên môn quý báu cũng như đưa ra những định hướng thực tiễn giúp em tháo gỡ những vướng mắc trong quá trình xây dựng hệ thống và triển khai các giải pháp bảo mật.

Em cũng xin gửi lời cảm ơn đến Ban giám hiệu trường Đại học Ngoại ngữ - Tin học TP.HCM (HUFLIT) cùng các thầy cô khoa Công nghệ thông tin đã tạo điều kiện về cơ sở vật chất, phòng Lab và môi trường học tập hiện đại để em có thể thực hành, nghiên cứu và hiện thực hóa các ý tưởng của mình.

Cuối cùng, dù đã có nhiều cố gắng trong việc nghiên cứu và triển khai đề tài, nhưng do kiến thức và kinh nghiệm thực tế của bản thân còn hạn chế, đồ án chắc chắn không tránh khỏi những thiếu sót. Em rất mong nhận được những ý kiến đóng góp, phê bình từ thầy để đề tài được hoàn thiện hơn và làm hành trang vững chắc cho em trên con đường theo đuổi chuyên ngành An ninh mạng sau này.

Em xin chân thành cảm ơn!

MỤC LỤC

LỜI MỞ ĐẦU	5
LỜI CẢM ƠN.....	6
MỤC LỤC	7
Danh mục hình ảnh.....	10
CHƯƠNG 1. GIỚI THIỆU TỔNG QUAN VỀ DOANH NGHIỆP	11
1.1. Lĩnh vực kinh doanh.....	11
1.2. Tổ chức và quy mô của doanh nghiệp.....	11
1.2.1. Chi nhánh hoạt động	11
1.2.2 .Các bộ phận và Số lượng nhân viên.....	11
1.2.3. Chức năng sử dụng mạng của từng bộ phận	12
1.3. Yêu cầu và mục đích triển khai hệ thống	12
1.3.1. Phục vụ các hoạt động kinh doanh.....	12
1.3.2 .Các yêu cầu cơ bản về kỹ thuật.....	13
1.3.3. Khả năng nhân sự và tài chính	13
1.4. Thiết kế hệ thống mạng.....	13
1.4.1. Sơ đồ mạng vật lý (Physical Topology).....	13
1.4.2. Sơ đồ mạng logic và quy hoạch IP(Logical Topology)	14
BẢNG QUY HOẠCH IP CHI TIẾT	15
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT	16
2.1. Các dịch vụ hệ thống nội bộ.....	16
2.1.1. ADDS (Active Directory Domain Services).....	16
2.1.2. DNS (Domain Name System).....	16
2.1.3. DHCP(Dynamic Host Configuration Protocol)	16
2.1.4. Group Policy(GPO).....	16
2.1.5. File Server	17
2.1.6. IIS (Internet Information Services).....	17
2.2. Các dịch vụ bảo mật mạng	17
2.2.1. VPN (Virtual Private Network)	17

2.2.2. Proxy – Squid & SquidGuard	18
2.2.3. Firewall và pfSense	18
2.2.4. IDS (Intrusion Dection System).....	18
2.2.5. IPS (Instrusion Prevention System)	18
2.3. Tổng quan về các mối đe dọa an ninh mạng	19
2.3.1. Mã độc (Malware / Ransomware).....	19
2.3.2. Rò rỉ dữ liệu nội bộ	19
2.3.3. Tấn công mạng.....	19
Chương 3. XÂY DỰNG VÀ TRIỂN KHAI HỆ THỐNG BẢO MẬT	20
3.1. Xác định tài sản cần bảo vệ	20
3.2 Đánh giá rủi ro(Các mối đe dọa, lỗ hổng).....	20
3.3 Xây dựng chính sách bảo mật và các quy trình bảo mật.....	21
3.3.1. Chính sách bảo mật vật lý	21
3.3.2. Chính sách bảo mật hệ điều hành.....	21
3.3.3. Chính sách bảo mật mạng	22
3.3.4. Kế hoạch ứng phó sự cố và khôi phục sau thảm họa	22
3.4. Triển khai giải pháp.....	22
3.4.1. Kiểm soát truy cập	22
3.4.2. Bảo vệ dữ liệu	23
3.4.3. Triển khai các công nghệ bảo mật	24
3.4.4. Triển khai giám sát hệ thống và mạng	25
3.4.5. Sao lưu và phục hồi.....	28
Chương 4. Kết quả thực nghiệm	31
4.1. Active Directory Domain Services	31
4.2. Flie server	32
4.3. Group Policy.....	33
4.4. PFSense	35
4.5. Internet Information Services.....	37
4.6 Domain Name System.....	38
4.7 VPN	39
4.8 Proxy – Squid & SquidGuard.....	40
4.9 Intrusion Dection System	43

4.10 Intrusion Prevention System	44
Chương 5. Tổng kết	45
5.1. Kết luận	45
5.2. Hạn chế và hướng phát triển	46
Chương 6. Tài liệu tham khảo	48
Bảng phân chia công việc	49

Danh mục hình ảnh

Hình 1 Góc camera thứ nhất	25
Hình 2 Góc camera thứ hai	26
Hình 3 Góc camera thứ ba	26
Hình 4 Góc camera thứ tư	27
Hình 5 Góc camera thứ năm	27
Hình 6 Góc camera thứ sáu	28
Hình 7 Góc camera thứ bảy	28
Hình 8 Join doamin thành công	31
Hình 9 Chia sẻ file qua máy chỉ nhánh chỉ có quyền đọc	32
Hình 10 Phân quyền trong Group Policy Managerment	33
Hình 11 Thay đổi hình trên win 10	34
Hình 12 Cắm USB	34
Hình 13 Tải proxy squid	35
Hình 14 Set rules trong pfs	36
Hình 15 Win 10 truy cập web local host	37
Hình 16 DNS	38
Hình 17 Kết nối VPN thành công	39
Hình 18 Tải Proxy Squid	40
Hình 19 Tải thành công	41
Hình 20 Chặn FB và Youtube nhưng các dịch vụ khác vẫn hoạt động	42
Hình 21 Hệ thống phát hiện xâm nhập	43
Hình 22 Hệ thống ngăn ngừa xâm nhập	44

CHƯƠNG 1. GIỚI THIỆU TỔNG QUAN VỀ DOANH NGHIỆP

1.1. Lĩnh vực kinh doanh

Doanh nghiệp được lựa chọn làm bối cảnh cho đề án là Hệ thống bán lẻ thiết bị di động DCH Mobile. Lĩnh vực hoạt động cốt lõi của doanh nghiệp bao gồm: phân phối, bán lẻ thiết bị di động (điện thoại thông minh, máy tính bảng, máy tính xách tay), cung cấp phụ kiện công nghệ và các dịch vụ sửa chữa, bảo hành, cài đặt phần mềm chuyên sâu. Với đặc thù lưu trữ khối lượng lớn dữ liệu thông tin cá nhân khách hàng và dữ liệu giao dịch tài chính, yêu cầu về an toàn thông tin của doanh nghiệp được đặt lên hàng đầu.

1.2. Tổ chức và quy mô của doanh nghiệp

1.2.1. Chi nhánh hoạt động

Hiện tại, tổ chức của DCH Mobile bao gồm 01 Trụ sở chính (tích hợp không gian Showroom trưng bày và Văn phòng điều hành) và 01 Chi nhánh bán hàng quy mô nhỏ. Bên cạnh đó, Ban Giám đốc của hệ thống thường xuyên có các chuyến công tác từ xa nhưng vẫn yêu cầu duy trì kết nối liên tục vào mạng lưới nội bộ để xét duyệt tài liệu và theo dõi báo cáo doanh thu.

1.2.2. Các bộ phận và Số lượng nhân viên

Tổng quy mô nhân sự của hệ thống rơi vào khoảng 20 nhân viên, được phân bổ thành 4 phòng ban chuyên trách dựa trên chức năng nghiệp vụ, bao gồm:

- Ban Giám đốc (02 người): Chịu trách nhiệm quản lý, điều hành toàn bộ hoạt động kinh doanh.
- Phòng Kế toán (03 người): Quản lý dòng tiền, sổ sách, lương thưởng và thông tin đối tác thương mại.
- Phòng Kinh doanh / Bán hàng (10 người): Tiếp xúc trực tiếp với khách hàng, lên đơn, xuất hóa đơn và kiểm tra hàng hóa tồn kho.

- Phòng Kỹ thuật / Bảo hành (05 người): Tiếp nhận máy bảo hành, sửa chữa phần cứng, cài đặt hệ điều hành và phần mềm cho khách hàng.

1.2.3. Chức năng sử dụng mạng của từng bộ phận

Mỗi phòng ban có đặc thù sử dụng tài nguyên mạng và mức độ rủi ro an ninh khác nhau, cụ thể:

- Ban Giám đốc: Yêu cầu đặc quyền truy cập cao nhất vào mọi phân vùng dữ liệu. Cần khả năng truy cập an toàn từ xa (Remote Access) vào hệ thống mạng nội bộ công ty thông qua môi trường Internet công cộng.
- Phòng Kế toán: Xử lý và lưu trữ dữ liệu tài chính tuyệt mật. Hệ thống máy tính của bộ phận này yêu cầu mức độ cô lập cao, chỉ giao tiếp với máy chủ lưu trữ nội bộ và hạn chế tối đa việc truy cập Internet tự do nhằm phòng tránh rủi ro lây nhiễm mã độc tống tiền (Ransomware).
- Phòng Kinh doanh: Cần kết nối Internet và hệ thống Web Server nội bộ liên tục để tra cứu thông tin sản phẩm và lập đơn hàng. Tuy nhiên, để đảm bảo hiệu suất công việc, bộ phận này cần bị giới hạn quyền truy cập vào các nền tảng mạng xã hội và giải trí trong giờ hành chính.
- Phòng Kỹ thuật: Đặc thù công việc đòi hỏi tần suất truy cập Internet cao để tải các bản firmware, công cụ chẩn đoán lỗi phần mềm. Đây là khu vực tiềm ẩn rủi ro bảo mật lớn nhất, có nguy cơ trở thành điểm trung chuyển để virus hoặc mã độc xâm nhập và lây lan sang các phòng ban khác.

1.3. Yêu cầu và mục đích triển khai hệ thống

1.3.1. Phục vụ các hoạt động kinh doanh

Mục tiêu cốt lõi của việc triển khai hệ thống bảo mật là đảm bảo tính sẵn sàng (Availability) cho quy trình bán hàng liên tục 24/7. Đồng thời, bảo đảm tính bảo mật (Confidentiality) và tính toàn vẹn (Integrity) cho cơ sở dữ liệu khách hàng – tài sản sống

còn của một doanh nghiệp hoạt động trong lĩnh vực bán lẻ.

1.3.2 .Các yêu cầu cơ bản về kỹ thuật

Hệ thống mạng phải đáp ứng các tiêu chuẩn kỹ thuật khắt khe:

- Phân vùng mạng độc lập (Network Segmentation): Tách biệt hoàn toàn Vùng máy chủ (Server Zone) khỏi Vùng người dùng (User Zone) để ngăn ngừa lây nhiễm chéo.
- Kiểm soát vành đai: Trang bị hệ thống Tường lửa (Firewall) trung tâm nhằm quản lý chặt chẽ luồng dữ liệu vào/ra và tích hợp bộ lọc truy cập web (Web Filtering).
- Quản trị tập trung: Xây dựng hệ thống quản lý định danh người dùng và thiết bị tập trung (Domain Controller), hỗ trợ việc triển khai chính sách bảo mật (Group Policy) xuống toàn bộ máy trạm một cách tự động.

1.3.3. Khả năng nhân sự và tài chính

Được định vị là doanh nghiệp quy mô vừa và nhỏ (SME), ngân sách đầu tư cho hạ tầng Công nghệ thông tin có sự giới hạn. Do đó, DCH Mobile định hướng thiết kế hệ thống tối ưu hóa chi phí bằng cách tận dụng sức mạnh của phần mềm nguồn mở. Giải pháp được lựa chọn là hệ điều hành tường lửa pfSense – cung cấp khả năng định tuyến và bảo mật mạnh mẽ không thua kém các thiết bị phần cứng đắt tiền, kết hợp cùng hệ sinh thái quản trị có sẵn của Windows Server.

1.4. Thiết kế hệ thống mạng

Để đáp ứng các yêu cầu bảo mật khắt khe của doanh nghiệp, hạ tầng mạng của DCH Mobile được thiết kế theo mô hình phân vùng (Zone-based architecture). Hệ thống sử dụng Tường lửa pfSense làm trung tâm định tuyến, chia tách mạng nội bộ thành các vùng có mức độ tin cậy khác nhau nhằm cô lập rủi ro khi xảy ra sự cố an ninh.

1.4.1. Sơ đồ mạng vật lý (Physical Topology)

Mô tả kết nối: Tín hiệu Internet từ Nhà cung cấp dịch vụ (ISP) được kết nối trực

tiếp vào Cổng WAN của Tường lửa pfSense. Từ pfSense, hệ thống sử dụng các Switch ảo/vật lý để phân nhánh cáp mạng vào hai khu vực hoàn toàn riêng biệt: Khu vực Máy chủ (Server Room) và Khu vực làm việc của nhân viên (Phòng Kế toán, Kinh doanh, Kỹ thuật).

1.4.2. Sơ đồ mạng logic và quy hoạch IP(Logical Topology)

- **Quy hoạch dải địa chỉ IP:** Dựa trên thiết kế vật lý, hệ thống mạng logic được chia nhỏ thành 03 phân vùng (Subnet/VLAN) với các dải IP chuyên biệt, được quản lý và cấp phát như sau:

BẢNG QUY HOẠCH ĐỊA CHỈ IP HỆ THỐNG DCH MOBILE

Phân vùng (Zone)	Cổng mạng (Interface)	Dải địa chỉ IP (Subnet)	Thiết bị / Chức năng	Địa chỉ IP cụ thể
Vùng Mạng ngoài (WAN)	WAN (NAT)	Nhận động từ ISP (DHCP)	pfSense Firewall	Nhận DHCP
Vùng Máy chủ (DMZ / Server Zone)	OPT1 (VMnet2)	192.168.20.0/24	Cổng Gateway Tường lửa	192.168.20.1
			Windows Server 2022 (AD, DNS, File Server)	192.168.20.10 (IP Tĩnh)
Vùng Người dùng (LAN / User Zone)	LAN (VMnet1)	192.168.10.0/24	Cổng Gateway Tường lửa	192.168.10.1
			Windows 10 (Máy tính nhân viên)	Cấp phát động từ pfSense

BẢNG QUY HOẠCH IP CHI TIẾT

Phòng Ban / Đối tượng	Dải IP Quy hoạch	Quy tắc Firewall (Firewall Rules)
Gateway / Tường lửa	192.168.10.1	Điểm truy cập trung tâm (Default Gateway).
Ban Giám Đốc (IT)	192.168.10.2 ➔ .10.9	Quyền tối cao (Allow All). Truy cập mọi nơi.
Phòng Kế Toán	192.168.10.10 ➔ .10.29	Cấm ra Internet duyệt web. Chỉ cho phép truy cập vào DMZ (File Server Kế toán).
Phòng Bán Hàng	192.168.10.30 ➔ .10.59	Cho phép ra Internet nhưng bị chặn mạng xã hội. Không được vào DMZ trừ Web nội bộ (IIS).
Phòng Kỹ Thuật	192.168.10.60 ➔ .10.89	Cho phép ra Internet tự do tải Firmware. Tuyệt đối cấm truy cập vào DMZ để chống lây mã độc.
Mạng Khách (Guest Wi-Fi)	192.168.10.100 ➔ .10.200	(Dùng DHCP cấp phát động). Chỉ được phép ra WAN (Internet). Cấm tuyệt đối ping hay chạm vào bất kỳ IP nội bộ nào khác.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT

2.1. Các dịch vụ hệ thống nội bộ

2.1.1. ADDS (Active Directory Domain Services)

Active Directory Domain Services (ADDS) là một dịch vụ thư mục cốt lõi của Microsoft Windows Server. Đối với hệ thống DCH Mobile, ADDS đóng vai trò là cơ sở dữ liệu tập trung lưu trữ toàn bộ thông tin về tài nguyên mạng bao gồm: tài khoản người dùng, máy tính, nhóm và các chính sách bảo mật. Việc triển khai ADDS giúp doanh nghiệp quản lý định danh người dùng một cách nhất quán, cho phép nhân viên sử dụng một tài khoản duy nhất (Single Sign-On) để xác thực và truy cập vào các tài nguyên được cấp phép trên toàn bộ hệ thống, từ đó tăng cường bảo mật và giảm thiểu chi phí quản trị IT.

2.1.2. DNS (Domain Name System)

Hệ thống phân giải tên miền (DNS) là dịch vụ thiết yếu giúp chuyển đổi các tên miền dễ nhớ (ví dụ: dchmobile.vn) thành các địa chỉ IP (ví dụ: 192.168.20.10) mà máy tính có thể hiểu và giao tiếp được. Trong môi trường nội bộ, DNS được tích hợp chặt chẽ với Active Directory để định vị các dịch vụ máy chủ (Domain Controller, Global Catalog). Nếu không có dịch vụ DNS nội bộ hoạt động ổn định, các máy trạm (Client) sẽ không thể gia nhập tên miền (Join Domain) hoặc xác thực tài khoản người dùng thành công.

2.1.3. DHCP(Dynamic Host Configuration Protocol)

Giao thức cấu hình máy chủ động (DHCP) tự động hóa quá trình cấp phát địa chỉ IP, Subnet Mask, Default Gateway và địa chỉ DNS Server cho các thiết bị tham gia vào mạng lưới. Thay vì phải cấu hình thủ công từng địa chỉ IP cho hàng loạt máy tính, điện thoại tại cửa hàng, máy chủ DHCP sẽ quản lý một dải IP (Scope) và cho thuê (Lease) các địa chỉ này trong một khoảng thời gian nhất định. Điều này loại bỏ hoàn toàn rủi ro xung đột IP và giúp hệ thống mạng của DCH Mobile dễ dàng mở rộng khi có thiết bị mới kết nối.

2.1.4. Group Policy(GPO)

Group Policy Object (GPO) là công cụ kiểm soát mạnh mẽ đi kèm với Active Directory, cho phép quản trị viên thiết lập, quản lý và thực thi các cấu hình máy tính cũng

như chính sách bảo mật cho hàng loạt thiết bị cùng lúc. Thông qua GPO, doanh nghiệp có thể áp dụng các rào cản an ninh nghiêm ngặt như: vô hiệu hóa cổng USB để chống rò rỉ dữ liệu, bắt buộc độ phức tạp của mật khẩu, tự động ánh xạ (Map) ổ đĩa mạng chia sẻ, hoặc hạn chế quyền cài đặt phần mềm của người dùng thông thường.

2.1.5. File Server

File Server (Máy chủ tệp tin) là một máy chủ trung tâm được cấu hình riêng biệt để lưu trữ, quản lý và chia sẻ tệp tin cho người dùng trong mạng nội bộ. Bằng việc phân quyền truy cập chi tiết thông qua các nhóm bảo mật của Active Directory (NTFS Permissions), File Server đảm bảo rằng chỉ những nhân viên có thẩm quyền mới được phép đọc, ghi hoặc chỉnh sửa dữ liệu, đáp ứng nghiêm ngặt nhu cầu bảo mật dữ liệu kế toán và hợp đồng tại công ty.

2.1.6. IIS (Internet Information Services)

Internet Information Services (IIS) là dịch vụ web máy chủ linh hoạt và an toàn do Microsoft phát triển, được sử dụng để lưu trữ các ứng dụng web và trang web trên nền tảng Windows. Trong kiến trúc hệ thống của doanh nghiệp, IIS được triển khai để cung cấp nền tảng hoạt động cho các trang web quản trị nội bộ hoặc phần mềm ERP, cho phép nhân viên các bộ phận tra cứu thông tin sản phẩm và lập báo cáo nhanh chóng thông qua giao diện trình duyệt web.

2.2. Các dịch vụ bảo mật mạng

2.2.1. VPN (Virtual Private Network)

Mạng riêng ảo (VPN) là công nghệ tạo ra một kết nối mạng an toàn và được mã hóa khi truyền dữ liệu qua các mạng công cộng kém an toàn như Internet. Trong bối cảnh DCH Mobile có chi nhánh hoạt động và Ban Giám đốc thường xuyên làm việc từ xa, giải pháp OpenVPN được tích hợp trên pfSense sẽ đóng vai trò như một "đường hầm bảo mật" (Secure Tunnel). Công nghệ này cho phép các máy trạm ở bên ngoài xác thực và truy cập vào vùng máy chủ (DMZ) của trụ sở chính để tra cứu tồn kho hoặc báo cáo tài chính một cách an toàn, ngăn chặn tuyệt đối rủi ro bị đánh cắp dữ liệu trên đường truyền (Man-in-the-Middle).

2.2.2. Proxy – Squid & SquidGuard

Proxy Server hoạt động như một trạm trung chuyển giữa người dùng nội bộ và Internet. Tại DCH Mobile, Squid Proxy được sử dụng để lưu trữ tạm thời (cache) các trang web thường xuyên được truy cập, giúp tăng tốc độ duyệt web và tiết kiệm băng thông. Hơn thế nữa, khi kết hợp với bộ lọc SquidGuard, hệ thống tạo ra một cơ chế kiểm soát nội dung (Web Filtering) cực kỳ mạnh mẽ. Quản trị viên có thể thiết lập các chính sách chặn truy cập vào các trang web độc hại, hoặc giới hạn nhân viên phòng Kinh doanh truy cập vào các nền tảng mạng xã hội (Facebook, TikTok) trong giờ làm việc để đảm bảo năng suất và giảm thiểu nguy cơ lây nhiễm mã độc.

2.2.3. Firewall và pfSense

Tường lửa (Firewall) là tuyến phòng thủ vành đai quan trọng nhất của mọi hệ thống mạng, làm nhiệm vụ giám sát và kiểm soát luồng giao thông mạng vào/ra dựa trên các quy tắc bảo mật (Rules) được định trước. **pfSense** là một nền tảng tường lửa mã nguồn mở dựa trên hệ điều hành FreeBSD, cung cấp khả năng định tuyến (Routing) và kiểm tra trạng thái gói tin (Stateful Packet Inspection) ưu việt. Trong sơ đồ mạng của DCH Mobile, pfSense đóng vai trò là Gateway trung tâm, cô lập hoàn toàn vùng người dùng (LAN) với vùng máy chủ (DMZ), đảm bảo rằng chỉ những luồng dữ liệu hợp lệ mới được phép đi qua.

2.2.4. IDS (Intrusion Dection System)

Hệ thống phát hiện xâm nhập (IDS) là một giải pháp giám sát mạng thụ động. Chức năng chính của IDS là phân tích bản sao của các gói tin đang lưu thông trên mạng, so sánh chúng với một cơ sở dữ liệu chứa các dấu hiệu tấn công đã biết (Signatures) hoặc các hành vi bất thường (Anomalies). Khi phát hiện có dấu hiệu bị quét lỗi (Scan Port) hoặc các nỗ lực xâm nhập vào máy chủ DCH Mobile, IDS sẽ ngay lập tức ghi log và gửi cảnh báo đến quản trị viên, tuy nhiên nó không tự động can thiệp vào luồng mạng để chặn cuộc tấn công.

2.2.5. IPS (Instrusion Prevention System)

Khác với sự thụ động của IDS, Hệ thống ngăn ngừa xâm nhập (IPS) là một giải pháp phòng thủ chủ động được đặt trực tiếp trên luồng giao thông mạng (In-line). Khi phát hiện một gói tin độc hại, IPS không chỉ đưa ra cảnh báo mà còn có khả năng tự động thực

thi các hành động ngăn chặn theo thời gian thực như: hủy bỏ (drop) gói tin độc hại, ngắt kết nối hoặc khóa địa chỉ IP của kẻ tấn công. Trong đồ án này, công cụ **Suricata** sẽ được triển khai trên pfSense để đảm nhiệm đồng thời cả hai vai trò IDS/IPS, tạo ra một lá chắn thép bảo vệ hệ thống trước các kỹ thuật tấn công phức tạp.

2.3. Tổng quan về các mối đe dọa an ninh mạng

2.3.1. Mã độc (Malware / Ransomware)

Phần mềm độc hại (Malware), đặc biệt là mã độc tống tiền (Ransomware), là mối đe dọa nghiêm trọng nhất đối với hệ thống DCH Mobile. Các phòng ban như Kỹ thuật (thường xuyên tải firmware) hoặc Kế toán (tiếp nhận hóa đơn điện tử) rất dễ trở thành nạn nhân của các chiến dịch Phishing email. Nếu xâm nhập thành công, Ransomware có thể lây lan qua mạng LAN, mã hóa toàn bộ cơ sở dữ liệu khách hàng và dữ liệu tài chính trên File Server, gây gián đoạn hoàn toàn hoạt động kinh doanh.

2.3.2. Rò rỉ dữ liệu nội bộ

Rò rỉ dữ liệu (Data Leakage) có thể xảy ra do sự vô ý hoặc cố ý từ chính nhân viên trong công ty. Khối lượng lớn dữ liệu nhạy cảm bao gồm thông tin định danh khách hàng, lịch sử giao dịch và hợp đồng đối tác là mục tiêu có giá trị cao. Rủi ro này thường xuất phát từ việc nhân viên tự ý sử dụng các thiết bị lưu trữ ngoại vi (USB, ổ cứng di động) hoặc tải dữ liệu lên các dịch vụ lưu trữ đám mây cá nhân chưa được phê duyệt.

2.3.3. Tấn công mạng

Hệ thống mạng nội bộ luôn phải đối mặt với các kỹ thuật tấn công đa dạng từ bên ngoài và bên trong. Các nỗ lực quét cổng (Port Scanning) nhằm dò tìm lỗ hổng trên Windows Server; các cuộc tấn công từ chối dịch vụ (DoS) nhắm vào Web Server nội bộ làm tê liệt khả năng tra cứu sản phẩm; hay các kỹ thuật nghe lén (Sniffing) trên môi trường mạng nếu dữ liệu truyền tải không được mã hóa... là những mối đe dọa hiện hữu đòi hỏi phải có một kiến trúc bảo mật đa lớp để phòng ngừa.

Chương 3. XÂY DỰNG VÀ TRIỂN KHAI HỆ THỐNG BẢO MẬT

3.1. Xác định tài sản cần bảo vệ

Để xây dựng một chiến lược bảo mật hiệu quả, bước đầu tiên là phải định danh và phân loại tài sản công nghệ thông tin của DCH Mobile:

- Tài sản phần cứng: Bao gồm Tường lửa pfSense (Gateway), Máy chủ vật lý (Server), hệ thống Switch định tuyến và toàn bộ máy trạm (PC/Laptop) của nhân viên tại trụ sở và chi nhánh.
- Tài sản phần mềm và Hệ điều hành: Hệ điều hành mạng (pfSense, Windows Server 2022, Windows 10), phần mềm quản trị Active Directory, cơ sở dữ liệu nội bộ và các dịch vụ mạng (DNS, DHCP, IIS).
- Tài sản Dữ liệu (Quan trọng nhất): Bao gồm cơ sở dữ liệu khách hàng (thông tin định danh, lịch sử mua hàng), chứng từ kế toán, báo cáo tài chính, tài khoản phân quyền quản trị và các mã nguồn/firmware gốc phục vụ bảo hành.

3.2 Đánh giá rủi ro(Các mối đe dọa, lỗ hổng)

Dựa trên kiến trúc mạng và đặc thù nghiệp vụ, hệ thống đối mặt với 3 nhóm rủi ro cốt lõi:

1. Rủi ro lây nhiễm chéo từ Vùng Người dùng (User Zone): Bộ phận Kỹ thuật thường xuyên tiếp xúc với các file firmware không rõ nguồn gốc trên Internet. Nếu một máy trạm bị nhiễm Ransomware, mã độc có thể quét mạng nội bộ (Scan IP) và lây lan sang Vùng Máy chủ (Server Zone) nếu không có tường lửa ngăn chặn.
2. Rủi ro rò rỉ dữ liệu nội bộ: Nhân viên bán hàng hoặc nhân viên kỹ thuật có thể sử dụng USB cá nhân để sao chép trái phép dữ liệu khách hàng hoặc file kế toán đem ra khỏi công ty.
3. Rủi ro truy cập trái phép: Các nỗ lực truy cập vào Server Kế toán từ mạng Wi-Fi Khách hàng, hoặc rủi ro đánh cắp dữ liệu khi Ban Giám đốc sử dụng Wi-Fi công cộng để kết nối về công ty mà không qua đường truyền mã hóa.

3.3 Xây dựng chính sách bảo mật và các quy trình bảo mật

Để vô hiệu hóa các rủi ro đã nhận diện và đảm bảo Hệ thống Quản lý An toàn Thông tin (ISMS) hoạt động hiệu quả, DCH Mobile áp dụng khung chính sách bảo mật dựa trên các miền kiểm soát (Control Domains) cốt lõi của tiêu chuẩn quốc tế ISO/IEC 27001. Khung chính sách này tuân thủ nguyên tắc "Phòng thủ chiều sâu" (Defense in Depth) và được quy định cụ thể như sau:

3.3.1. Chính sách bảo mật vật lý

- **Kiểm soát khu vực an toàn:** Máy chủ Windows Server và Tường lửa trung tâm (pfSense) phải được đặt trong Phòng Máy chủ (Server Room) cách ly hoàn toàn với khu vực bán hàng. Cửa ra vào phải có khóa vật lý hoặc thẻ từ, kết hợp camera giám sát 24/7.
- **An toàn thiết bị:** Hệ thống thiết bị lõi phải được trang bị bộ lưu điện (UPS) để đảm bảo tính sẵn sàng (Availability) và tránh hỏng hóc phần cứng khi xảy ra sự cố mất điện lưới đột ngột. Chỉ nhân sự quản trị mạng (IT Admin) mới được phép tiếp xúc vật lý với thiết bị.

3.3.2. Chính sách bảo mật hệ điều hành

- **Kiểm soát truy cập người dùng (User Access Management):** Áp dụng nguyên tắc "Đặc quyền tối thiểu" (Least Privilege). Việc phân quyền truy cập trên File Server phải được thực hiện thông qua Domain Controller, đảm bảo nhân viên phòng nào chỉ được phép đọc/ghi dữ liệu của phòng đó.
- **Chính sách xác thực và Mật khẩu (Thông qua GPO):** Bắt buộc toàn bộ tài khoản gia nhập Domain phải áp dụng chính sách mật khẩu phức tạp (tối thiểu 8 ký tự, bao gồm chữ hoa, chữ thường, số, ký tự đặc biệt) và yêu cầu thay đổi định kỳ 60 ngày/lần.
- **Bảo mật thiết bị đầu cuối (End-point Security):** Vô hiệu hóa việc sử dụng các cổng lưu trữ ngoại vi (USB, ổ cứng rời) trên tất cả các máy trạm của bộ phận Bán hàng và Kế toán bằng Group Policy Object (GPO) nhằm chống rò rỉ dữ liệu. Tự động khóa màn hình (Lock screen) sau 5 phút không có thao tác.

3.3.3. Chính sách bảo mật mạng

- **Kiểm soát mạng lưới (Network Controls):** Triển khai kiến trúc mạng phân vùng (VLAN/Subnet) thông qua pfSense. Áp dụng nguyên tắc "Zero Trust" bằng cách khóa tất cả các cổng (Block All) giữa Vùng Người dùng (LAN) và Vùng Máy chủ (DMZ), chỉ cho phép (Allow) các luồng giao thông hợp lệ được định nghĩa trước.
- **Kiểm soát dịch vụ Web:** Sử dụng Proxy Server để lọc nội dung web (Web Filtering). Hạn chế các máy trạm thuộc bộ phận Bán hàng truy cập vào mạng xã hội và các trang web không phục vụ công việc nhằm tối ưu băng thông và giảm thiểu nguy cơ lây nhiễm mã độc.
- **Bảo mật truyền tải thông tin (Information Transfer):** Mọi truy cập từ xa vào hệ thống mạng nội bộ (của Ban Giám đốc hoặc nhân viên làm việc từ xa) bắt buộc phải thiết lập qua đường hầm Mạng riêng ảo (OpenVPN) có xác thực bằng chứng chỉ (Certificate) để chống kỹ thuật nghe lén (Man-in-the-Middle).

3.3.4. Kế hoạch ứng phó sự cố và khôi phục sau thảm họa

- **Giám sát và Ứng phó sự cố (Incident Management):** Triển khai hệ thống Suricata (IDS/IPS) giám sát lưu lượng mạng theo thời gian thực. Khi phát hiện các hành vi quét cổng (Port Scan) hoặc lưu lượng bất thường, hệ thống tự động ngăn chặn (Drop) IP nguồn và gửi cảnh báo (Alert) đến quản trị viên.
- **Sao lưu và Phục hồi (Business Continuity):** Toàn bộ cơ sở dữ liệu và tệp tin quan trọng trên File Server phải được sao lưu tự động hàng ngày (Daily Backup) vào một phân vùng ổ đĩa độc lập. Kế hoạch phục hồi (Disaster Recovery) phải được thử nghiệm định kỳ để đảm bảo dữ liệu có thể được khôi phục ngay lập tức khi hệ thống bị tấn công Ransomware.

3.4. Triển khai giải pháp

3.4.1. Kiểm soát truy cập

Mục tiêu cốt lõi của kiểm soát truy cập là đảm bảo nguyên tắc "quyền hạn tối thiểu" (Principle of Least Privilege), chỉ cấp phép cho đúng người, đúng thiết bị vào

đúng tài nguyên cần thiết.

- **Cơ chế Xác thực (Authentication):** Hệ thống yêu cầu xác thực mạnh mẽ đối với mọi luồng truy cập. Triển khai mô hình quản lý tập trung **AAA (Authentication, Authorization, Accounting)** thông qua các giao thức bảo mật mạng tiêu chuẩn để kiểm soát và ghi log toàn bộ quá trình đăng nhập của thiết bị và người dùng. Khuyến khích áp dụng Xác thực đa yếu tố (MFA) đối với các tài khoản quản trị (Admin).
- **Cơ chế Phân quyền (Authorization):** Áp dụng mô hình **Kiểm soát truy cập dựa trên vai trò (RBAC - Role-Based Access Control)**. Người dùng được phân vào các nhóm quyền hạn cụ thể (ví dụ: Quản trị viên, Nhân viên, Khách) và hệ thống sẽ kiểm tra nghiêm ngặt quyền hạn này ở cấp độ API và logic nghiệp vụ, nhằm ngăn chặn triệt để các lỗ hổng leo thang đặc quyền hay tham chiếu đối tượng trực tiếp không an toàn (IDOR).
- **Quản lý phiên (Session Management):** Thiết lập thời gian sống (timeout) cho các phiên kết nối không hoạt động. Mã thông báo xác thực (Token/Cookie) được mã hóa, gán cờ HttpOnly và Secure để chống lại các cuộc tấn công đánh cắp phiên.

3.4.2. Bảo vệ dữ liệu

Chiến lược bảo vệ dữ liệu tập trung vào việc duy trì tính bảo mật, tính toàn vẹn và tính sẵn sàng của dữ liệu trong cả ba trạng thái: Đang truyền tải, Đang lưu trữ và Đang sử dụng.

- **Bảo vệ dữ liệu đang truyền tải (Data in Transit):** Toàn bộ lưu lượng giao tiếp giữa máy khách (Client) và máy chủ (Server), cũng như giữa các thành phần nội bộ của hệ thống đều được mã hóa bằng giao thức TLS 1.2 hoặc TLS 1.3. Hủy bỏ hỗ trợ cho các giao thức cũ, kém an toàn.

- **Bảo vệ dữ liệu lưu trữ (Data at Rest):** Các thông tin nhạy cảm trong cơ sở dữ liệu (như mật khẩu, khóa bí mật, thông tin cá nhân) phải được mã hóa trước khi lưu trữ. Sử dụng các thuật toán băm an toàn có salt (như bcrypt hoặc Argon2) cho mật khẩu, và mã hóa chuẩn công nghiệp (như AES-256) cho các dữ liệu quan trọng khác. Các cơ chế lọc đầu vào (Input Validation) và tham số hóa truy vấn (Parameterized Queries) được áp dụng triệt để nhằm bảo vệ cơ sở dữ liệu khỏi nguy cơ SQL Injection.
- **Sao lưu và Phục hồi (Backup & Recovery):** Xây dựng chính sách sao lưu định kỳ (hàng ngày/hàng tuần) với quy tắc lưu trữ 3-2-1. Dữ liệu sao lưu cũng phải được mã hóa và kiểm tra khả năng phục hồi thường xuyên để đảm bảo hệ thống có thể khôi phục nhanh chóng trong trường hợp xảy ra sự cố.

3.4.3. Triển khai các công nghệ bảo mật

Để hiện thực hóa các chính sách trên, hệ thống áp dụng chiến lược "Phòng thủ chiều sâu" (Defense in Depth) bằng cách triển khai kết hợp nhiều lớp công nghệ bảo mật.

- **Bảo mật mạng và Định tuyến (Network Security):** Triển khai hệ thống tường lửa (Firewall) mạnh mẽ để kiểm soát lưu lượng ra/vào hạ tầng. Hệ thống mạng được phân vùng (Network Segmentation) rõ ràng giữa các khu vực DMZ, mạng nội bộ và mạng quản trị. Có thể triển khai các giải pháp như **pfsense** để đóng vai trò làm Gateway, thiết lập các quy tắc tường lửa nghiêm ngặt, NAT và hỗ trợ VPN an toàn cho việc quản trị từ xa.
- **Bảo mật Ứng dụng (Application Security):** Triển khai Tường lửa Ứng dụng Web (WAF) để phân tích lưu lượng HTTP/HTTPS, giúp tự động phát hiện và ngăn chặn các mẫu tấn công phổ biến như Cross-Site Scripting (XSS), SQL Injection và các hành vi tải lên tập tin không hạn chế (Unrestricted File

Upload).

- **Giám sát và Cảnh báo (Monitoring & Alerting):** Triển khai các công cụ giám sát hiệu suất và an ninh mạng theo thời gian thực. Toàn bộ log truy cập, log lỗi từ máy chủ web, cơ sở dữ liệu và tường lửa được đẩy về một hệ thống quản lý tập trung. Hệ thống này sẽ phân tích các dấu hiệu bất thường (ví dụ: đăng nhập sai quá nhiều lần, lưu lượng truy cập tăng đột biến) và gửi cảnh báo ngay lập tức cho đội ngũ quản trị qua email hoặc các nền tảng tin nhắn tích hợp.

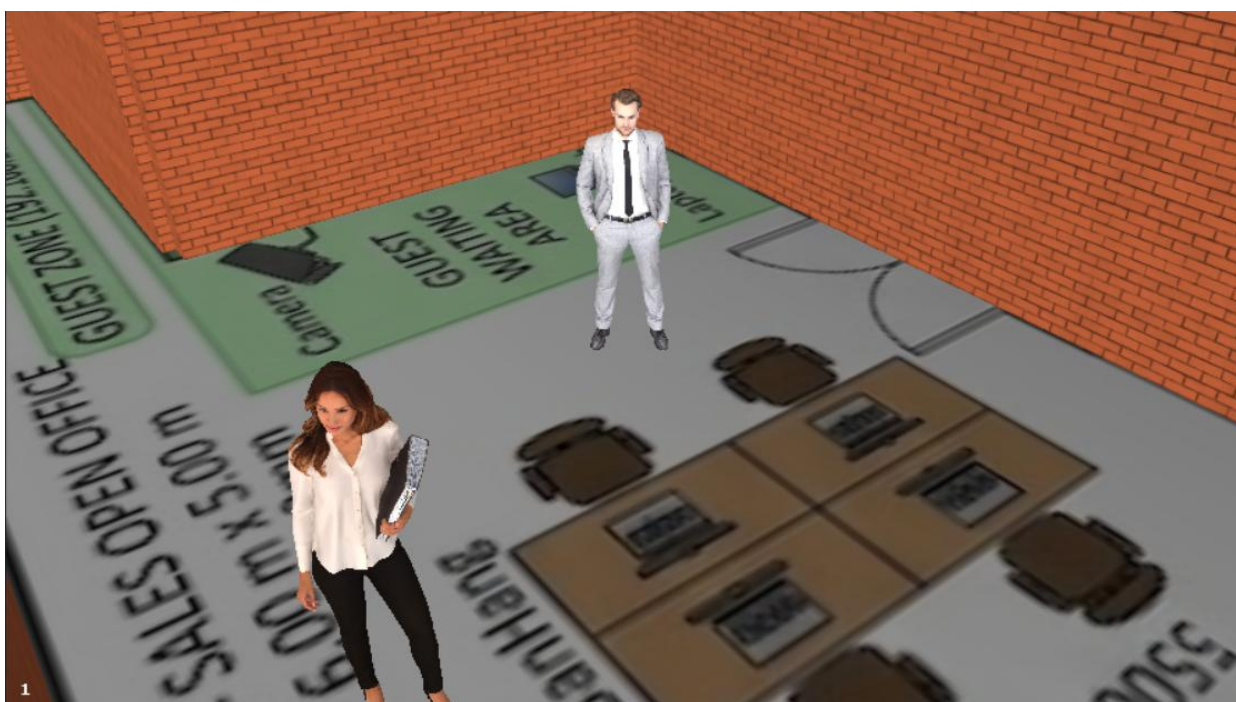
3.4.4. Triển khai giám sát hệ thống và mạng



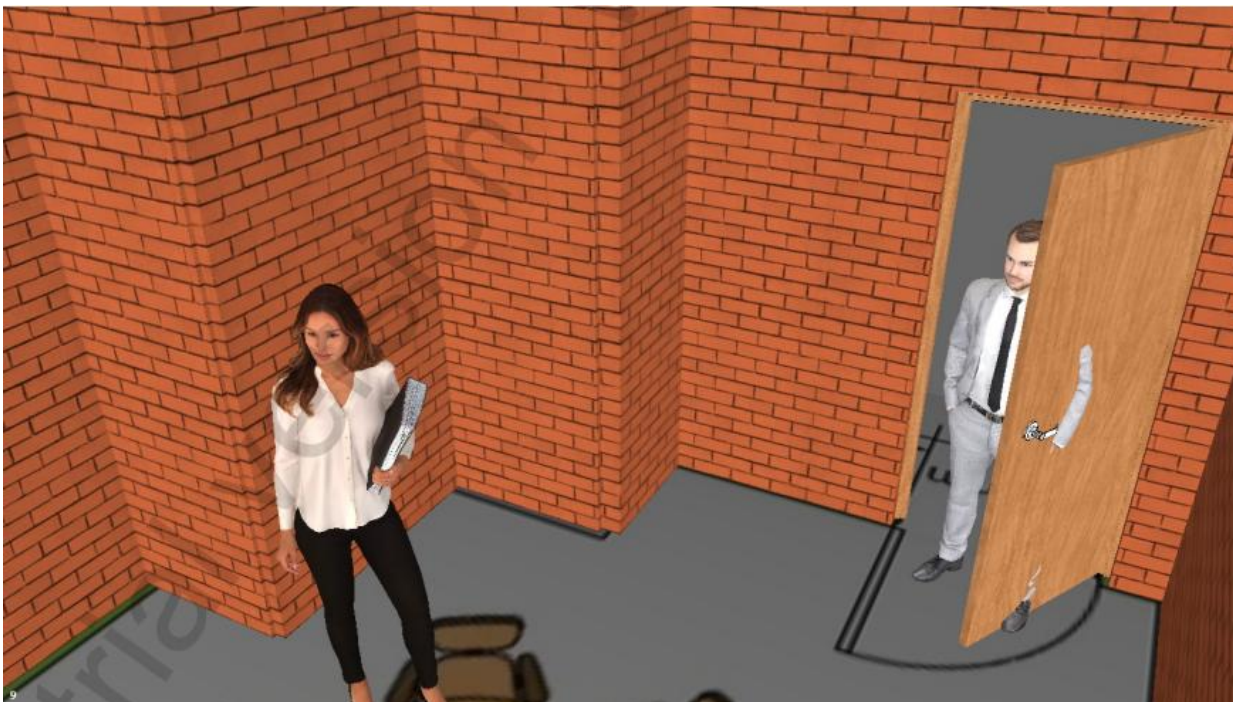
Hình 1 Góc camera thứ nhất



Hình 2 Góc camera thứ hai



Hình 3 Góc camera thứ ba



Hình 4 Góc camera thứ tư



Hình 5 Góc camera thứ năm



Hình 6 Góc camera thứ sáu



Hình 7 Góc camera thứ bảy

3.4.5. Sao lưu và phục hồi

Mục tiêu của chính sách sao lưu và phục hồi là đảm bảo tính sẵn sàng của hệ thống, duy trì hoạt động kinh doanh liên tục và hạn chế tối đa thiệt hại do mất mát

dữ liệu khi đối mặt với các rủi ro như tấn công mạng (đặc biệt là Ransomware), lỗi sự cố phần cứng, hoặc sai sót từ con người.

- **Chiến lược Sao lưu (Backup Strategy):**

- ❖ **Quy tắc 3-2-1:** Áp dụng tiêu chuẩn công nghiệp với ít nhất 3 bản sao của dữ liệu, lưu trữ trên 2 loại phương tiện vật lý hoặc môi trường khác nhau, và ít nhất 1 bản sao được lưu trữ bên ngoài hạ tầng mạng nội bộ (off-site hoặc Cloud Storage).

- ❖ **Phân loại và Chu kỳ:** Kết hợp linh hoạt các phương pháp sao lưu. Thực hiện sao lưu toàn phần (Full Backup) theo định kỳ (ví dụ: hàng tuần) kết hợp với sao lưu gia tăng (Incremental Backup) hoặc sao lưu khác biệt (Differential Backup) hàng ngày nhằm tối ưu hóa dung lượng lưu trữ và băng thông mạng.

- ❖ **Bảo mật bản sao lưu:** Toàn bộ dữ liệu sao lưu phải được mã hóa mạnh (ví dụ: AES-256) ở trạng thái lưu trữ. Phân tách mạng (Network Segmentation) và áp dụng kiểm soát truy cập nghiêm ngặt đối với máy chủ backup để ngăn chặn rủi ro mã độc tổng tiền lây lan sang các bản sao lưu.

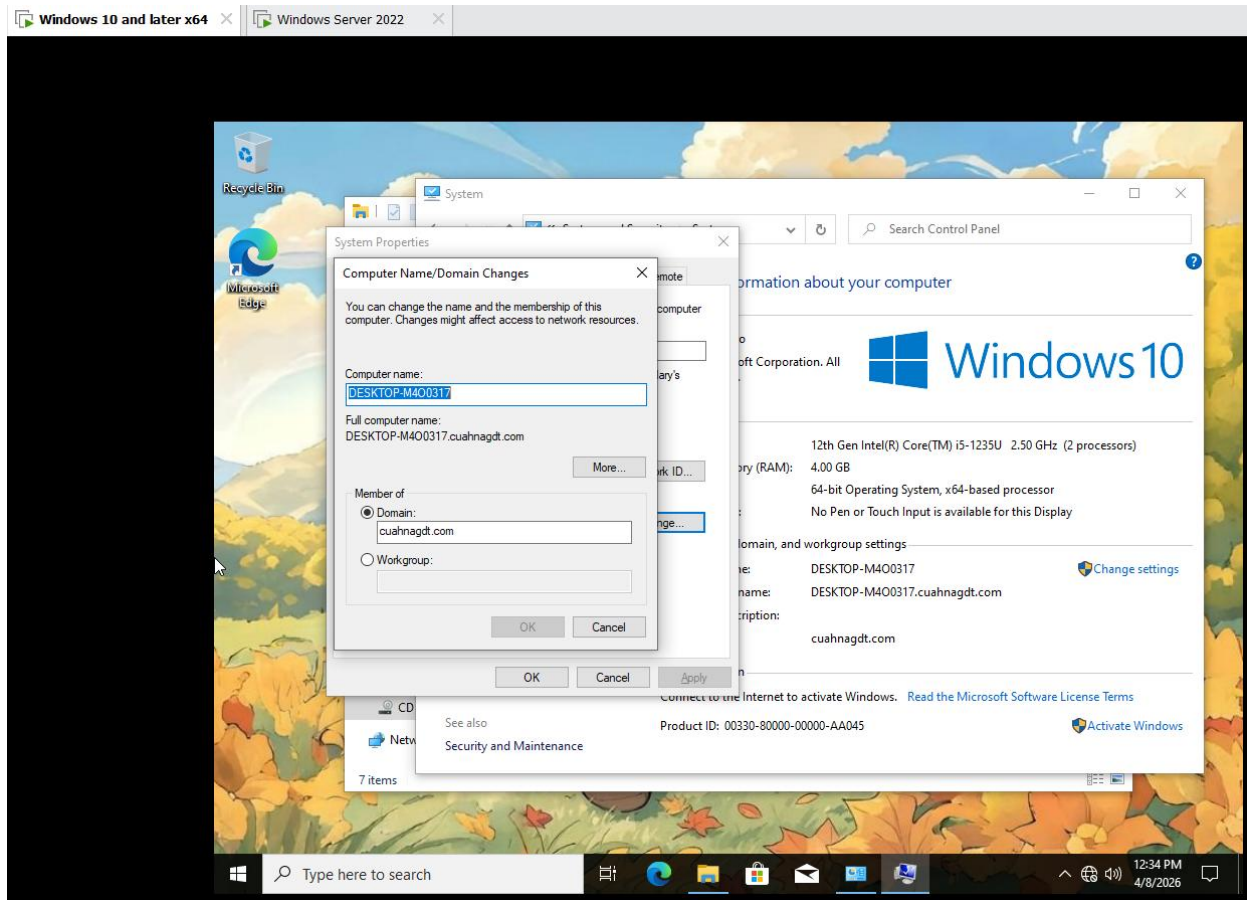
- **Kế hoạch Phục hồi (Disaster Recovery Plan - DRP):**

- ❖ **Chỉ số mục tiêu (RPO & RTO):** Xác định rõ Thời gian phục hồi mục tiêu (RTO - Recovery Time Objective) và Điểm phục hồi mục tiêu (RPO - Recovery Point Objective) dựa trên mức độ ưu tiên của từng thành phần trong hệ thống (ví dụ: Cơ sở dữ liệu người dùng cần RPO ngắn hơn so với log hệ thống).

- ❖ **Quy trình chuẩn hóa:** Xây dựng tài liệu Hướng dẫn thao tác chuẩn (SOP) chi tiết từng bước để khôi phục hạ tầng. Quá trình này bao gồm việc dựng lại cấu hình mạng, khôi phục máy chủ ứng dụng và khôi phục cơ sở dữ liệu về trạng thái hoạt động bình thường.
- **Kiểm thử và Đánh giá (Testing & Validation):**
 - ❖ Chỉ sao lưu thôi là chưa đủ; khả năng phục hồi phải được kiểm chứng. Lên lịch diễn tập phục hồi (Restoration Drill) định kỳ (hàng quý hoặc bán niên) trên một môi trường sandbox cô lập.
 - ❖ Việc diễn tập giúp đánh giá tính toàn vẹn của các file backup, đo lường thời gian thực tế so với RTO dự kiến, và đảm bảo đội ngũ vận hành nắm vững quy trình xử lý khi thảm họa thực sự xảy ra.

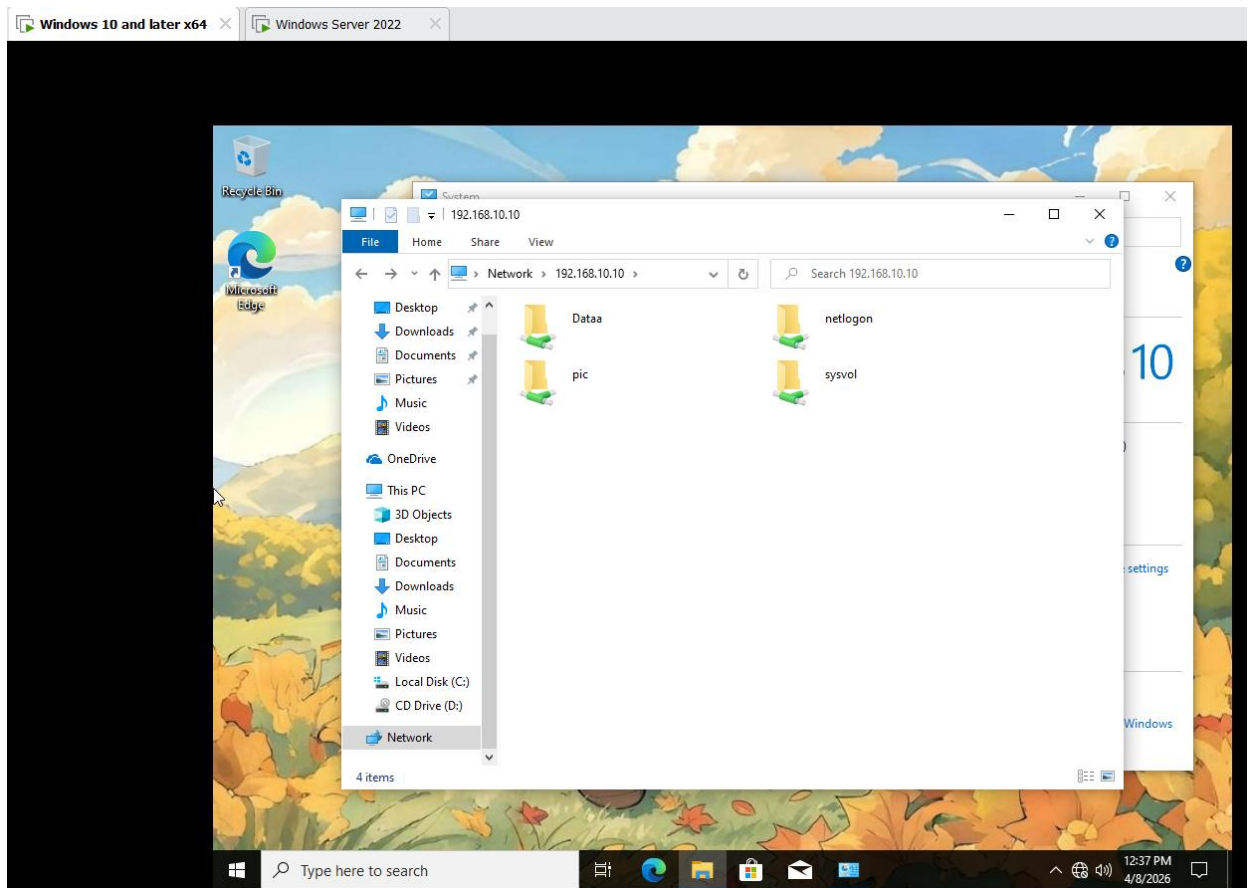
Chương 4. Kết quả thực nghiệm

4.1. Active Directory Domain Services



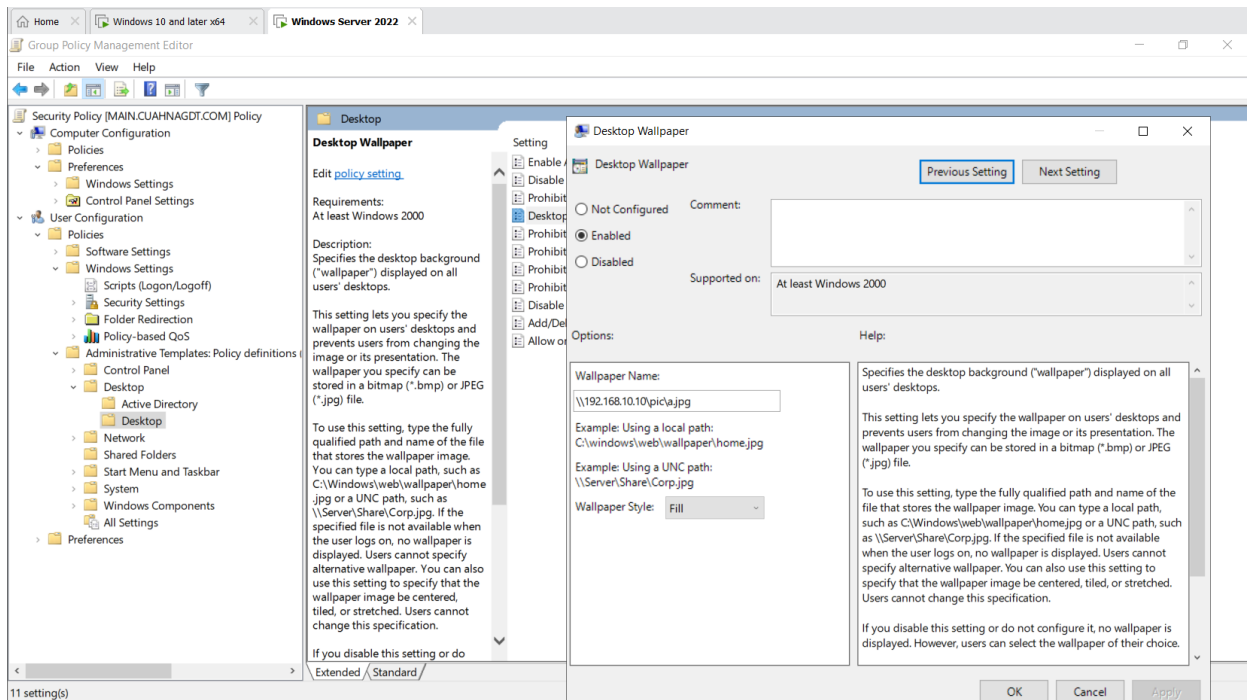
Hình 8 Join domain thành công

4.2. Flie server

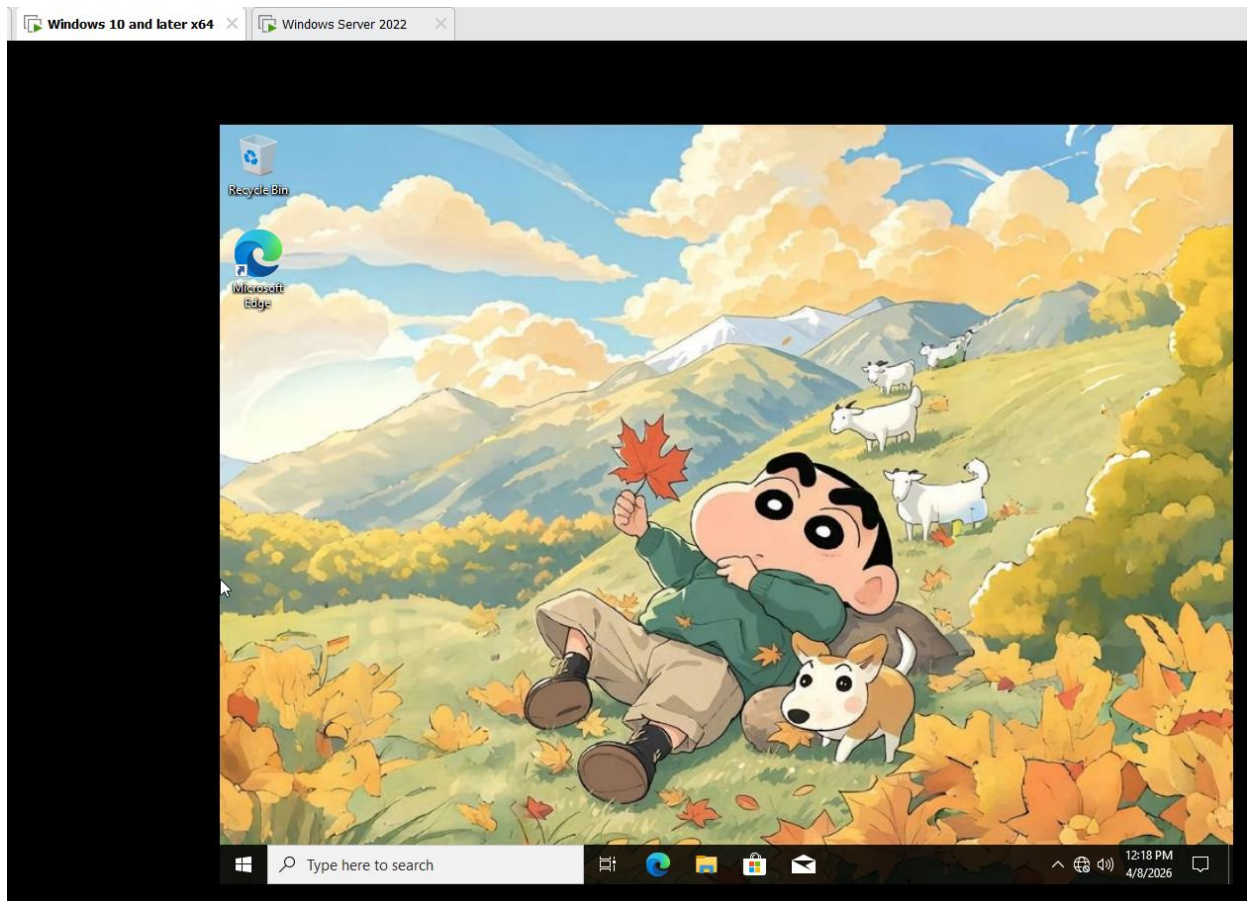


Hình 9 Chia sẻ file qua máy chủ nhánh chỉ có quyền đọc

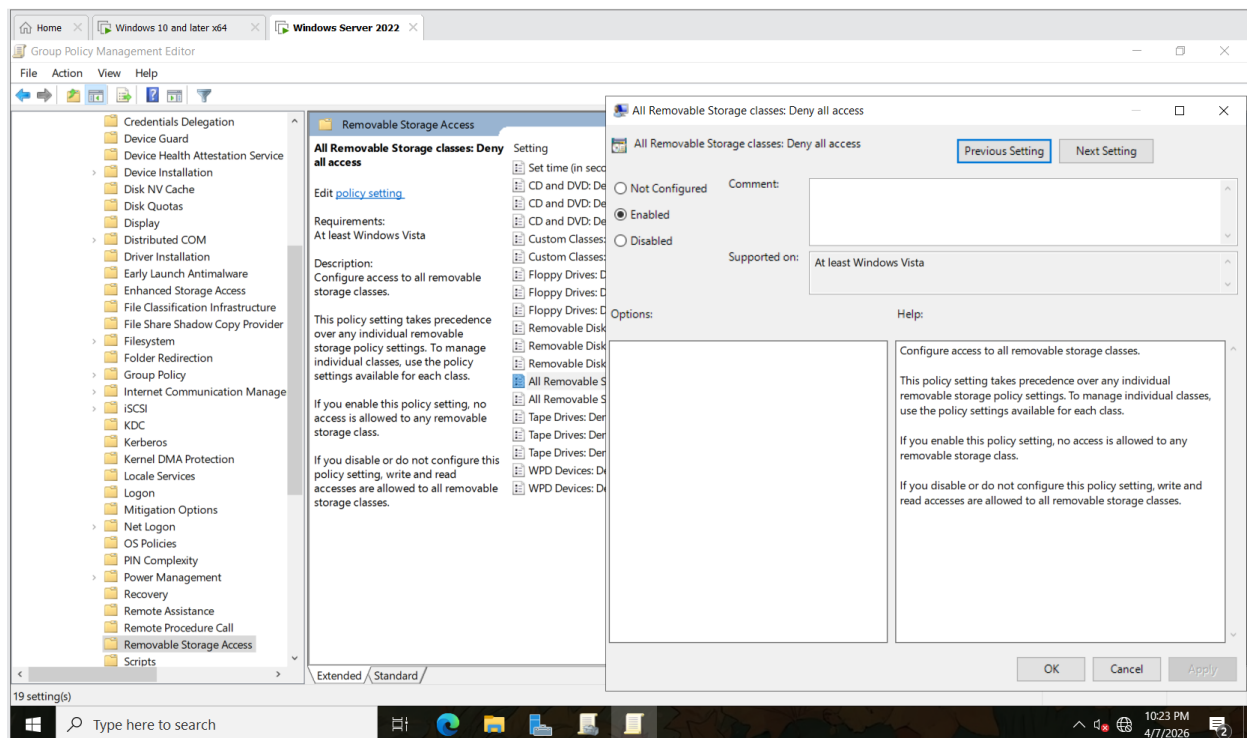
4.3. Group Policy



Hình 10 Phân quyền trong Group Policy Management

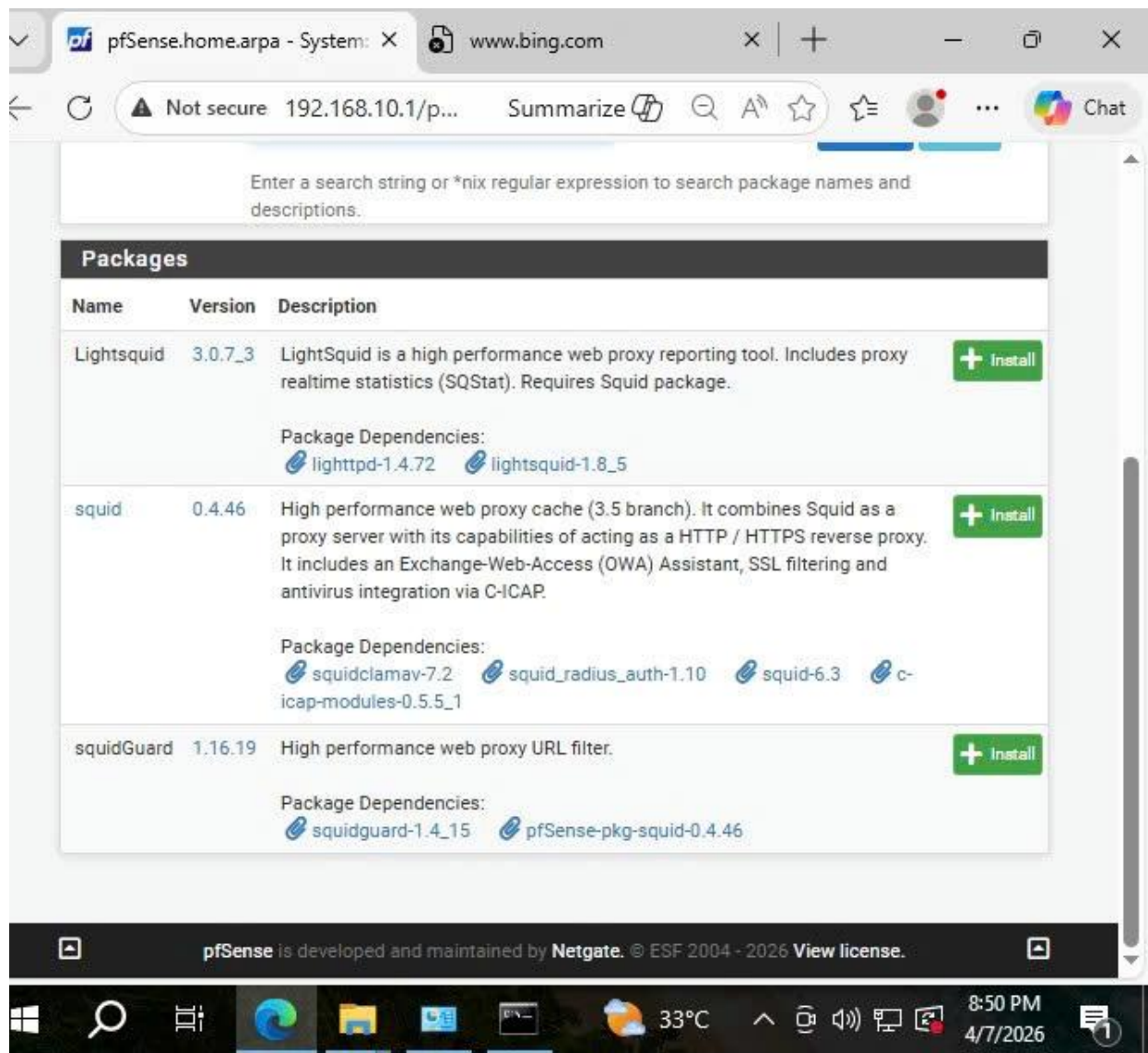


Hình 11 Thay đổi hình trên win 10



Hình 12 Cấm USB

4.4. PFSense

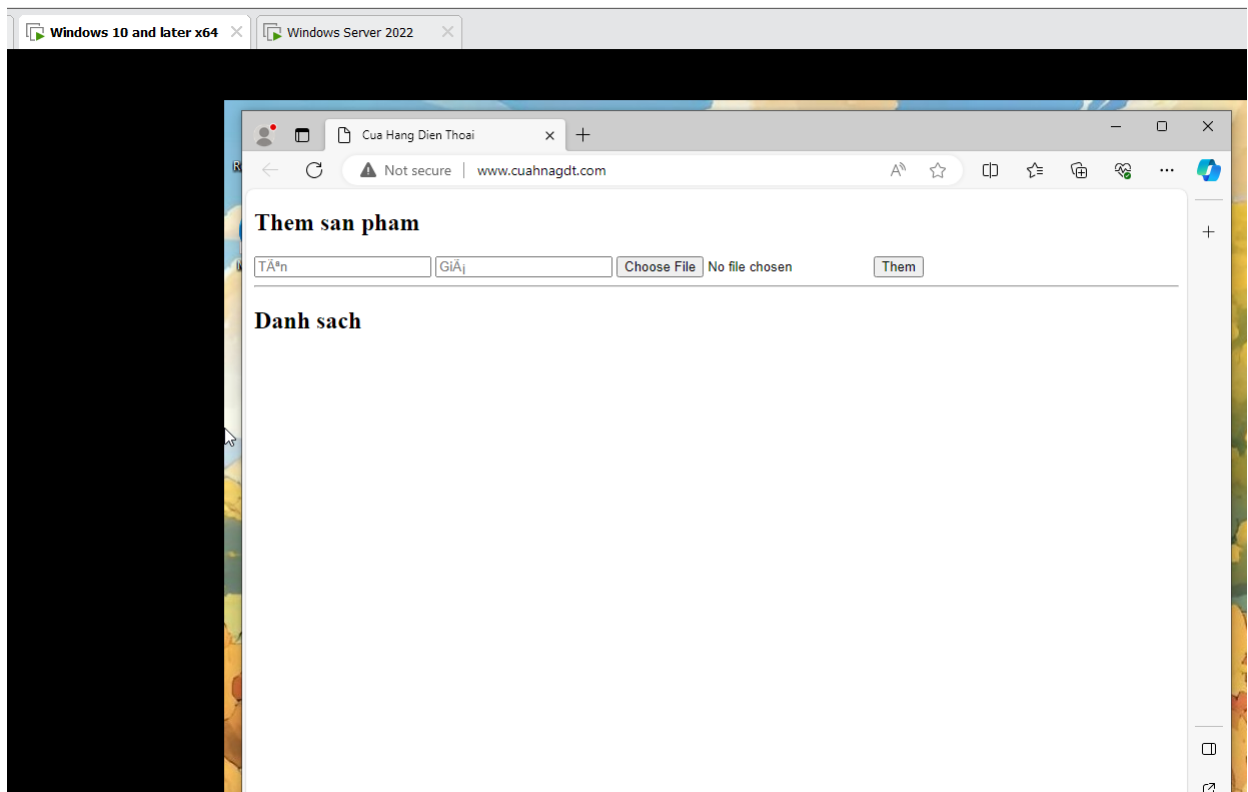


Hình 13 Tải proxy squid

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	2/2.15 MiB	*	*	*	LAN Address	80	*	*		Anti-Lockout Rule	
☐	✗ 0/0 B	IPv4 *	BanHang_Group	*	youtube	*	*	none		chan ban hang vao yt	
☐	✗ 0/0 B	IPv4 *	BanHang_Group	*	Facebook	*	*	none		Chan Ban Hang vao Facebook.	
☐	0/0 B	IPv4 *	*	*	pfB_PRI1_v4	*	*	none		pfB_PRI1_v4	
☐	0/56.94 MiB	IPv4 *	IT_Admin	*	*	*	*	none			
☐	6/17.04 MiB	IPv4 *	BanGiamDoc	*	*	*	*	none			
☐	0/28 KiB	IPv4 TCP/UDP	KeToan_Group	*	DMZ subnets	DMZ_Services	*	none			
☐	0/11.58 MiB	IPv4 TCP/UDP	BanHang_Group	*	*	Port_NoiBo	*	none			
☐	✗ 0/3 KiB	IPv4 *	LAN subnets	*	DMZ subnets	*	*	none			
☐	✗ 0/3 KiB	IPv4 *	Guest_Group	*	LAN subnets	*	*	none			
☐	✗ 0/147 KiB	IPv4 *	KeToan_Group	*	*	*	*	none		Nhot Ke Toan khong cho ra Interne	
☐	0/130.97 MiB	IPv4 *	LAN subnets	*	*	*	*	none			

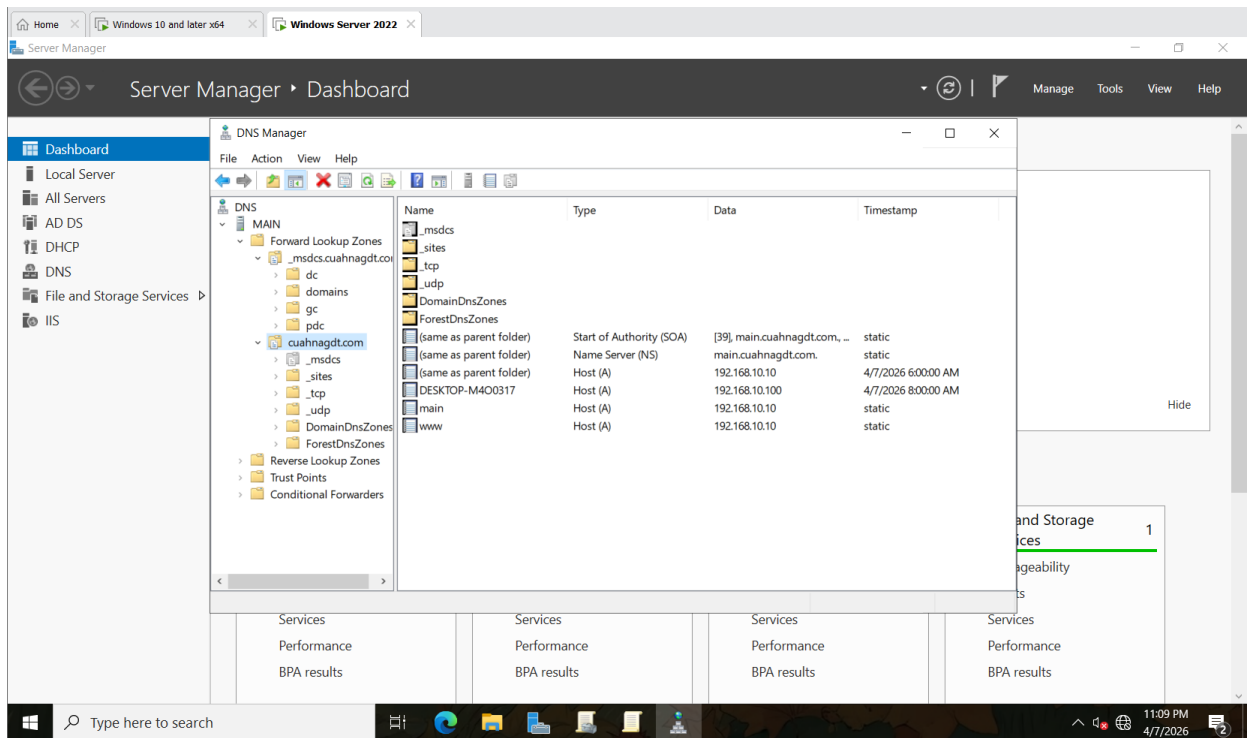
Hình 14 Set rules trong pfs

4.5. Internet Information Services



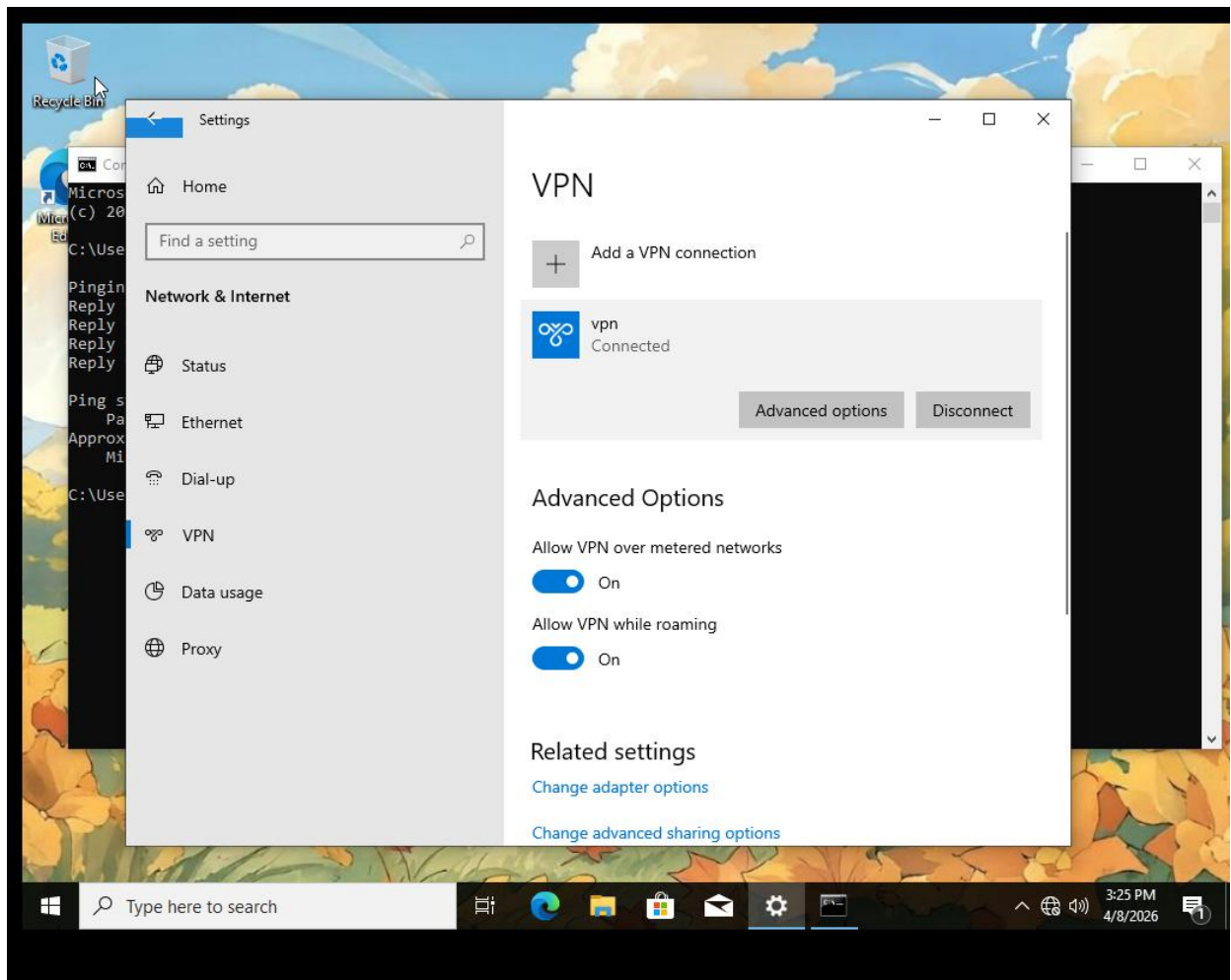
Hình 15 Win 10 truy cập web local host

4.6 Domain Name System



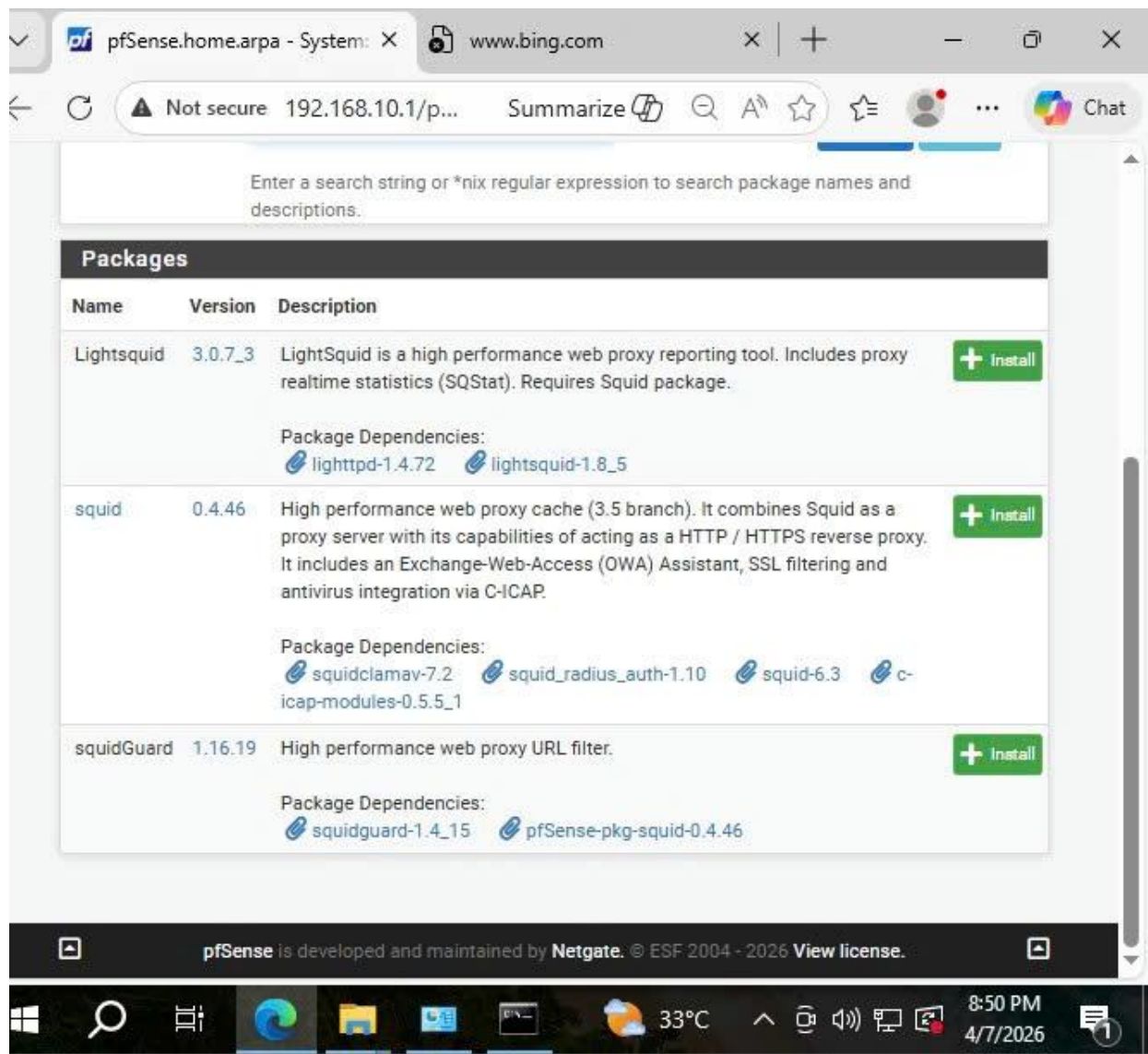
Hình 16 DNS

4.7 VPN

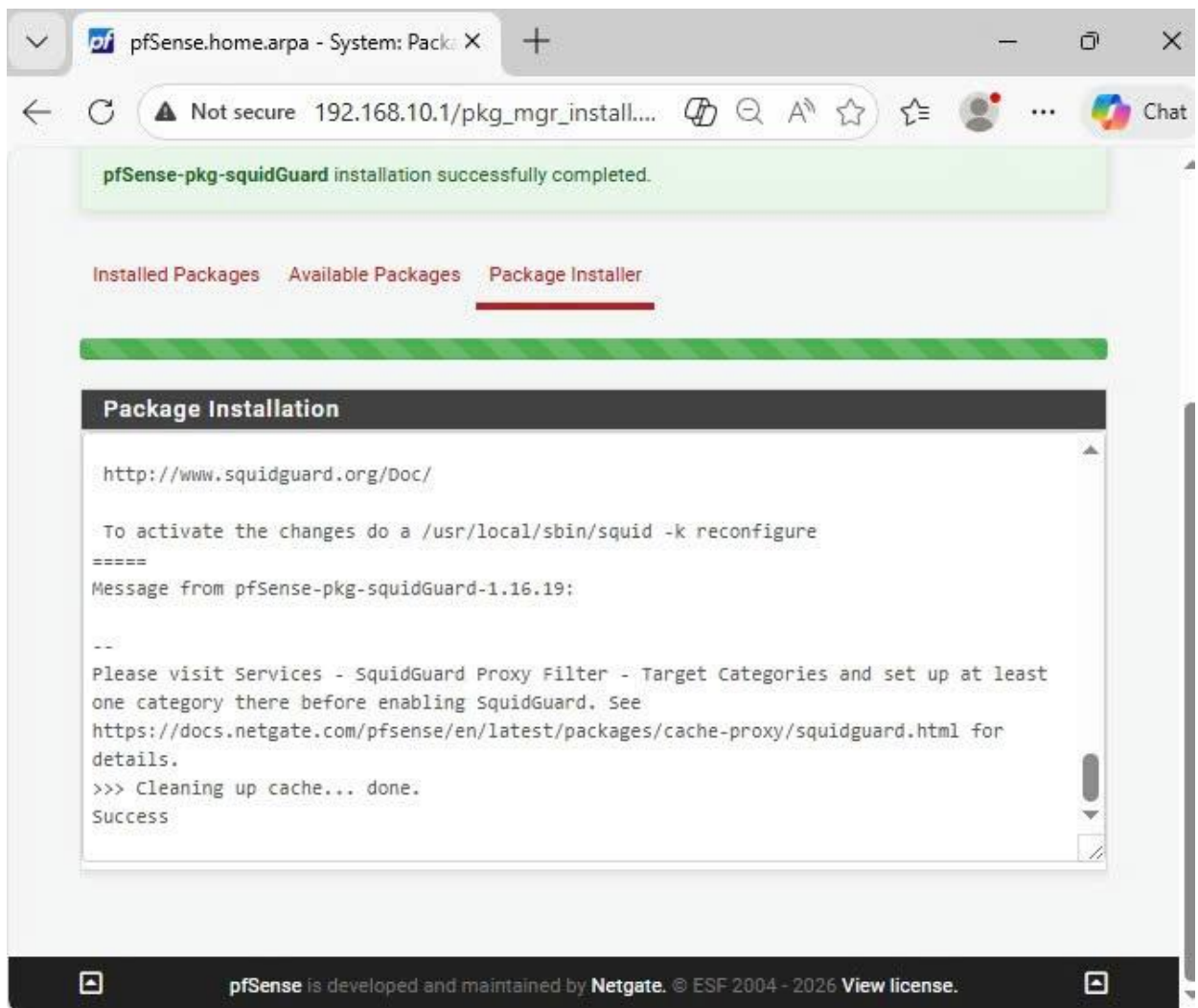


Hình 17 Kết nối VPN thành công

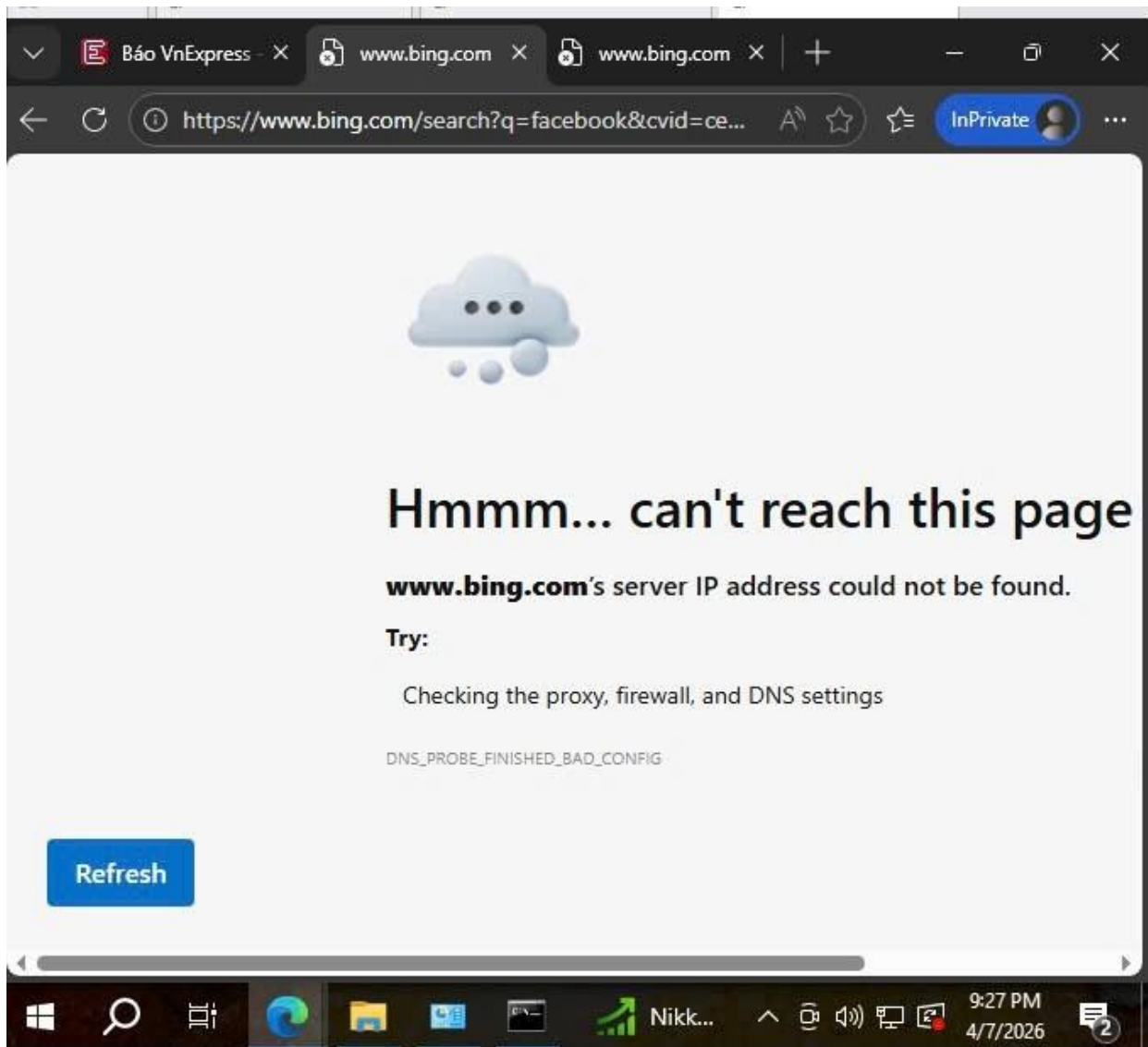
4.8 Proxy – Squid & SquidGuard



Hình 18 Tải Proxy Squid

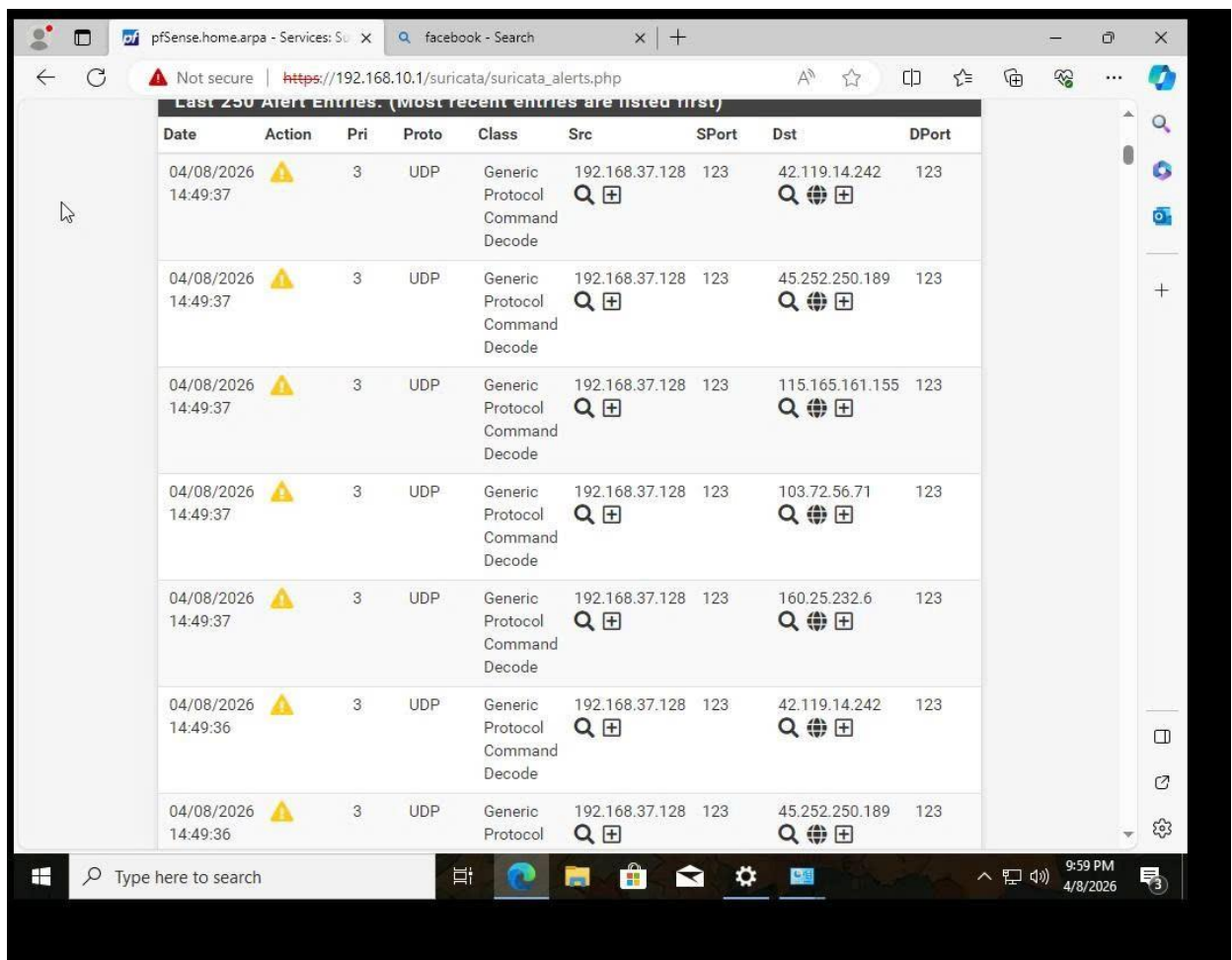


Hình 19 Tải thành công



Hình 20 Chặn FB và Youtube nhưng các dịch vụ khác vẫn hoạt động

4.9 Intrusion Dection System



The screenshot displays the pfSense web interface, specifically the Suricata alerts page. The browser address bar shows the URL https://192.168.10.1/suricata/suricata_alerts.php. The page title is "Last 250 Alert Entries. (most recent entries are listed first)". The table below lists several alerts, all of which are "Generic Protocol Command Decode" events. Each alert entry includes a date and time, an action icon (yellow triangle with an exclamation mark), a priority of 3, a protocol of UDP, and source/destination IP addresses and ports. The alerts are listed in descending order of time, with the most recent at the top.

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort
04/08/2026 14:49:37	⚠	3	UDP	Generic Protocol Command Decode	192.168.37.128	123	42.119.14.242	123
04/08/2026 14:49:37	⚠	3	UDP	Generic Protocol Command Decode	192.168.37.128	123	45.252.250.189	123
04/08/2026 14:49:37	⚠	3	UDP	Generic Protocol Command Decode	192.168.37.128	123	115.165.161.155	123
04/08/2026 14:49:37	⚠	3	UDP	Generic Protocol Command Decode	192.168.37.128	123	103.72.56.71	123
04/08/2026 14:49:37	⚠	3	UDP	Generic Protocol Command Decode	192.168.37.128	123	160.25.232.6	123
04/08/2026 14:49:36	⚠	3	UDP	Generic Protocol Command Decode	192.168.37.128	123	42.119.14.242	123
04/08/2026 14:49:36	⚠	3	UDP	Generic Protocol Command Decode	192.168.37.128	123	45.252.250.189	123

Hình 21 Hệ thống phát hiện xâm nhập

4.10 Intrusion Prevention System

The screenshot shows the pfSense web interface for the Suricata intrusion prevention system. The 'Blocks' tab is selected in the top navigation bar. Below the navigation bar, there are links for 'Interfaces', 'Global Settings', 'Updates', 'Alerts', 'Blocks', 'Files', 'Pass Lists', 'Suppress', 'Logs View', 'Logs Mgmt', 'SID Mgmt', 'Sync', and 'IP Lists'. The main content area is titled 'Blocked Hosts Log View Settings' and contains several controls: a 'Download' button, a 'Clear' button, a 'Save or Remove Hosts' section, a 'Save Settings' button, a 'Refresh' checkbox, and a text input for the number of blocked entries to view (set to 500). Below this is a section titled 'Last 500 Hosts Blocked by Suricata' with a note about Legacy Mode interfaces. A table lists the blocked IP addresses, block dates/times, alert descriptions, and block rule GID:SID. The table shows one entry: 20.42.73.27 blocked on 04/08/2026 at 15:24:29 by rule 1:2210029. A status bar at the bottom indicates '1 host IP address is currently being blocked.' The footer of the interface states 'pfSense is developed and maintained by Netgate. © ESF 2004 - 2026 View license.'

Interfaces Global Settings Updates Alerts **Blocks** Files Pass Lists Suppress Logs View

Logs Mgmt SID Mgmt Sync IP Lists

Blocked Hosts Log View Settings

Save or Remove Hosts [Download](#) [Clear](#)

All blocked hosts will be saved All blocked hosts will be cleared

Save Settings [Save](#) ☒ Refresh

Save auto-refresh and view settings Default is ON Number of blocked entries to view. Default is 500

Last 500 Hosts Blocked by Suricata

Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are **highlighted** on the ALERTS tab.

Blocked IP	Block Date/Time	Block Alert Description	Block Rule GID:SID	Remove Block
20.42.73.27	04/08/2026 15:24:29	SURICATA STREAM ESTABLISHED invalid ack	1:2210029	×

1 host IP address is currently being blocked.

pfSense is developed and maintained by Netgate. © ESF 2004 - 2026 View license.

Hình 22 Hệ thống ngăn ngừa xâm nhập

Chương 5. Tổng kết

5.1. Kết luận

Đồ án đã trình bày chi tiết quá trình nghiên cứu, thiết kế và xây dựng một hệ thống mạng an toàn, đáp ứng được các yêu cầu khắt khe về bảo mật và tính sẵn sàng cho doanh nghiệp DCH Mobile. Thông qua việc bám sát các tiêu chuẩn an toàn thông tin cơ bản, quá trình triển khai đã đạt được những kết quả trọng tâm sau:

- **Xây dựng hạ tầng mạng phân vùng an toàn:** Đã triển khai thành công kiến trúc mạng Zone-based với trung tâm là Tường lửa pfSense. Hệ thống đã cô lập hoàn toàn Vùng Máy chủ (DMZ) và Vùng Người dùng (LAN), giúp hạn chế tối đa rủi ro lây nhiễm chéo mã độc từ các phòng ban nghiệp vụ.
- **Quản trị định danh và kiểm soát truy cập tập trung:** Ứng dụng thành công hệ sinh thái Windows Server (Active Directory, DNS, DHCP) để quản lý tập trung. Hệ thống đã thiết lập các chính sách bảo mật (GPO) nghiêm ngặt như: bắt buộc độ phức tạp mật khẩu, phân quyền truy cập File Server theo nguyên tắc đặc quyền tối thiểu, và vô hiệu hóa cổng USB nhằm ngăn chặn rò rỉ dữ liệu.
- **Triển khai phòng thủ vành đai và giám sát:** Tích hợp thành công các giải pháp bảo mật nguồn mở mạnh mẽ trên pfSense, bao gồm Suricata (IDS/IPS) để tự động phát hiện và ngăn chặn các hành vi xâm nhập, cùng với Squid & SquidGuard Proxy để kiểm soát, lọc nội dung truy cập Web của nhân viên.
- **Bảo mật kết nối từ xa và an toàn dữ liệu:** Đảm bảo kết nối an toàn cho Ban Giám đốc làm việc từ xa thông qua đường hầm bảo mật OpenVPN. Đồng thời, thiết lập các quy trình sao lưu theo quy tắc 3-2-1 để bảo vệ cơ sở dữ liệu khách hàng trước các nguy cơ tấn công tống tiền (Ransomware).

5.2. Hạn chế và hướng phát triển

Mặc dù giải pháp đã đáp ứng được các mục tiêu an ninh cơ bản, nhưng với đặc thù quy mô doanh nghiệp SME, hệ thống hiện tại vẫn tồn tại một số hạn chế và mở ra các hướng phát triển trong tương lai:

Hạn chế còn tồn tại:

- **Nguy cơ điểm lỗi duy nhất (Single Point of Failure):** Hiện tại, hệ thống đang phụ thuộc vào một thiết bị tường lửa pfSense và một máy chủ Windows Server duy nhất. Nếu xảy ra sự cố hỏng hóc phần cứng vật lý tại các thiết bị lỗi này, toàn bộ mạng lưới và dịch vụ xác thực của DCH Mobile sẽ bị gián đoạn.
- **Khả năng chịu tải của phần cứng:** Việc tích hợp quá nhiều dịch vụ nặng như Tường lửa, Định tuyến, Proxy Server (Squid) và đặc biệt là hệ thống phân tích gói tin liên tục (Suricata IDS/IPS) trên cùng một thiết bị pfSense có thể gây ra hiện tượng nghẽn cổ chai (bottleneck) khi lưu lượng mạng tăng cao.
- **Giám sát log phân tán:** Các bản ghi sự kiện (Log) hiện đang nằm rải rác ở nhiều nơi (pfSense, Windows Server, IIS). Quản trị viên phải kiểm tra thủ công từng hệ thống, dẫn đến độ trễ trong việc phát hiện và phản ứng trước các chuỗi tấn công mạng phức tạp.

Hướng phát triển trong tương lai:

1. **Triển khai Tính sẵn sàng cao (High Availability - HA):** Xây dựng hệ thống dự phòng bằng cách thiết lập cấu hình CARP (Common Address Redundancy Protocol) cho hai thiết bị tường lửa pfSense chạy song song. Đồng thời, triển khai thêm một máy chủ Domain Controller phụ (Additional DC) để đảm bảo dịch vụ phân giải tên miền và xác thực không bao giờ bị gián đoạn.
2. **Quản lý sự kiện an ninh mạng tập trung (SIEM):** Triển khai các giải pháp SIEM mã nguồn mở (như Wazuh hoặc ELK Stack) để thu thập, chuẩn hóa và

phân tích log từ tất cả các máy trạm, máy chủ và tường lửa về một màn hình duy nhất. Điều này giúp tự động hóa việc tương quan sự kiện và rút ngắn thời gian phản ứng sự cố.

3. **Tăng cường bảo mật điểm cuối (EDR/XDR):** Nâng cấp từ các chính sách GPO cơ bản lên các giải pháp phát hiện và phản hồi điểm cuối (Endpoint Detection and Response). Công nghệ này sử dụng phân tích hành vi để phát hiện các biến thể mã độc Zero-day hoặc Ransomware mà các hệ thống dựa trên chữ ký (Signature-based) như Suricata có thể bỏ sót.
4. **Triển khai xác thực đa yếu tố (MFA):** Tích hợp MFA cho dịch vụ kết nối từ xa OpenVPN và các tài khoản quản trị Domain Admin nhằm tăng cường một lớp bảo mật vật lý, chống lại các cuộc tấn công đánh cắp mật khẩu.

Chương 6. Tài liệu tham khảo

- [1] Bộ Thông tin và Truyền thông. (2020). *Tiêu chuẩn quốc gia TCVN ISO/IEC 27001:2020 về Công nghệ thông tin - Các kỹ thuật an toàn - Hệ thống quản lý an toàn thông tin - Các yêu cầu*.
- [2] Nguyễn Khắc Quốc. (2018). *Giáo trình Quản trị mạng Windows Server*. NXB Thông tin và Truyền thông.
- [3] Trần Quang Chiến. (2021). *An toàn bảo mật thông tin trong hệ thống mạng máy tính*. NXB Khoa học và Kỹ thuật.

Bảng phân chia công việc

Họ và tên	Nội dung công việc	Mức độ hoàn thành
Bùi Viết Nguyên Chương	Viết file báo cáo, tổng hợp lý thuyết, thiết kế hệ thống mạng, triển khai giám sát	100%
Phan Trần Anh Đức	Triển khai ADDS, file server, PFSence, IIS, tổng hợp nội dung, thực nghiệm	100%
Vũ Thị Thanh Huế	GP,DNS,VPN,Proxy-Squid, IDS, IPS, tổng hợp nội dung, thực nghiệm	100%